SECURITY NINJA GERMANY



SECURITY NINJA GERMANY

The Modern SecOps Playbook

Microsoft Sentinel Data Lake, Graphs, and Agentic Tools



Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

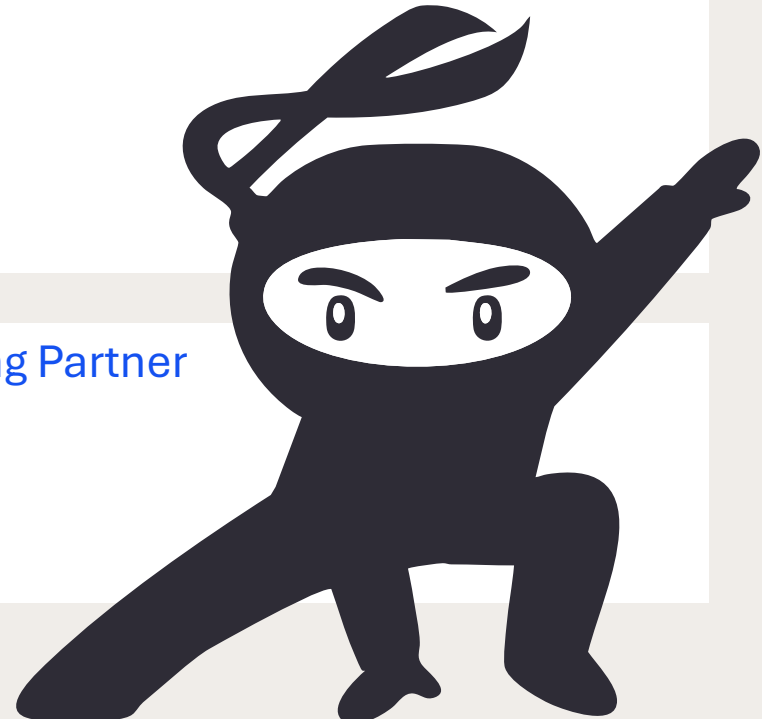
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



Agenda

SECURITY NINJA GERMANY

01 Introduction

02 The Modern SecOps Playbook

03 Sentinel Platform Innovations

04 Sentinel MCP Server

05 Perception MCP Server

06 Auditing

Sami Lamppu

SECURITY NINJA GERMANY

Security + AI in the Microsoft ecosystem

Kauniainen, Finland

samilamppu@com



EID Playbook & MSUGFI

Crossfit, weightlifting, any kind of sports

Samilamppu

Modern SecOps Playbook



Modern Investigation Stack – Sentinel Platform

The platform unifies data, context, and AI tools to enable faster and deeper investigation across the full kill chain

SECURITY NINJA GERMANY

Microsoft Sentinel Data Lake

- Single ingestion point with long-term retention, which enables historical pivoting and large-scale investigations

Sentinel Graph(s)

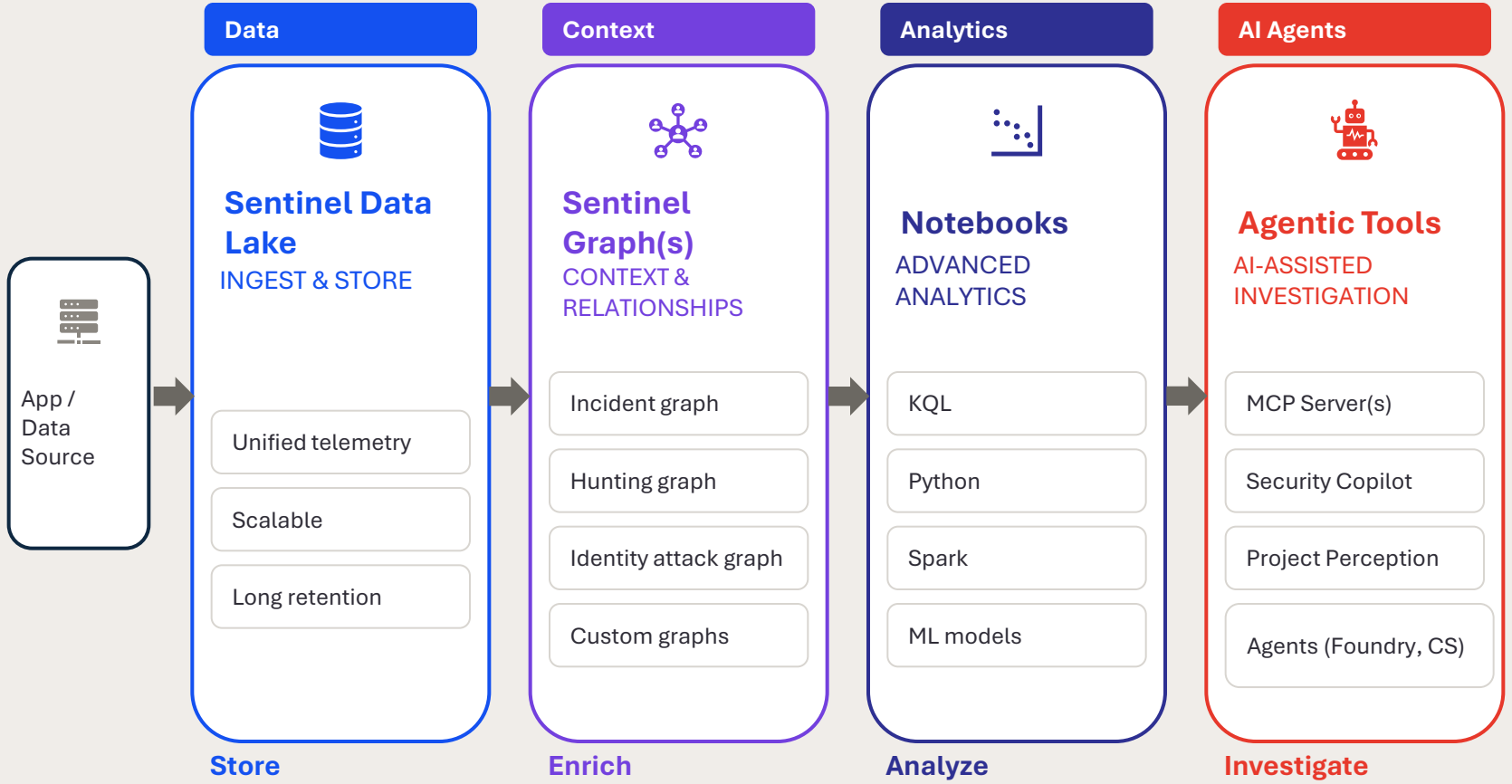
- Several graphs, identity relationships, attack paths, blast radius

Notebooks

- Deep analytics, enrichment, hunting, and custom graphs

Agentic tools

- Natural-language investigation and AI-assisted triage
- Perception, MCPs, AI Agents, SC



SECURITY NINJA GERMANY

Architecture



TL;DR slide



- Architecture
- What are a data lake and a Sentinel graph, actually?
- Tips from the research

Microsoft Sentinel platform architecture

SIEM · data lake · graph · MCP server · ISOC · Microsoft Fabric | Oct 2026

◆ ISOC announcement 23rd Sep 2026

DATA INTAKE
500+ connectors

- Microsoft 365
- Microsoft Defender XDR
- Microsoft Entra ID
- Azure Activity
- Syslog · CEF · REST API
- AWS · GCP
- Non-Microsoft solutions
- Custom connectors

ISOC data
Defender data is native; other sources connect through an ISOC workspace

CONSUME

Microsoft Defender portal

- **Incidents & cases**
- **Advanced hunting**
- **Attack disruption**
- **Sentinel graph**
  blast radius · hunting graph · custom graphs (GQL)
- **Workbooks**
- **Content hub**
- **Security Store**
- **APIs**

Microsoft Purview
data risk graph
retiring Nov 2026

ISOC · alternative entry path
Integrated Security Operations Center
Microsoft Defender Suite or Microsoft 365 E5/E7 without an active Sentinel workspace
No workspace: cases · workbooks · AI playbooks · automation rules
ISOC workspace: UEBA · Content hub · CI/CD · TI · third-party data
Retention: 30 → 90 days from 15 Nov 2026 (planned)

Microsoft Sentinel MCP server AI & agent access · hosted · Microsoft Entra auth · data exploration · triage · agent creation

PROCESS

Analytics tier (SIEM)
analytics rules · automation rules & playbooks · hunting · UEBA · threat intelligence

Data lake tools
KQL queries & jobs · Jupyter notebooks · custom graphs · summary rules · data federation

◆ Microsoft Fabric: custom security analytics

- **Mirror**
  workspace tables → OneLake
- **Analyze**
  KQL · notebooks · Fabric Graph

Federate: OneLake shortcuts · metadata mirroring
Fabric capacity required · new data only

STORE

Analytics tier · hot
high-performance KQL · up to 2 years

mirrored by default ⇄ promote via KQL / notebook jobs

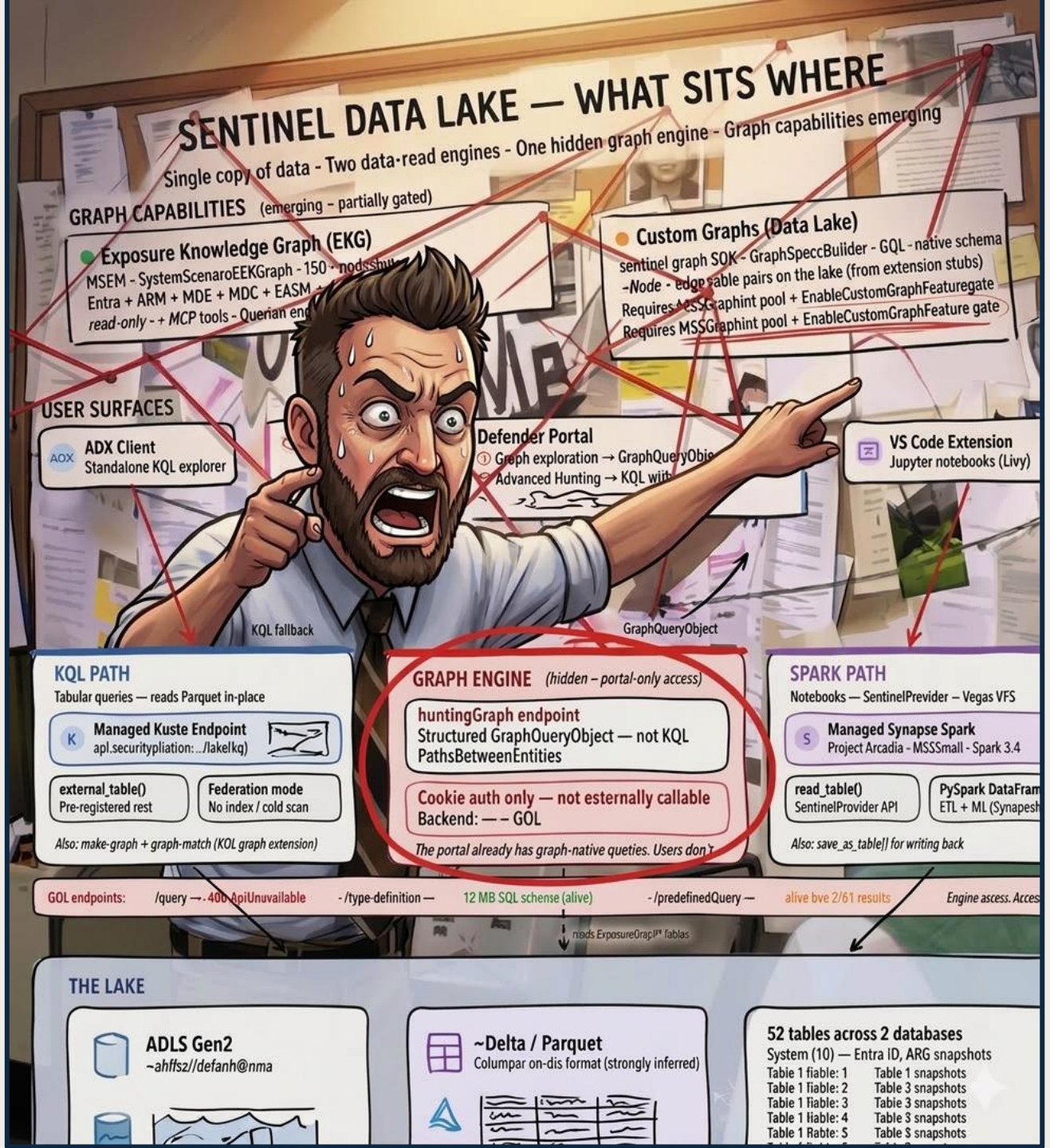
Data lake tier · cold
open Parquet · low cost · up to 12 years

◆ Table management
lake tier per table · no separate lake onboarding or billing

XDR default tier
30 days in advanced hunting · not in analytics or lake tier by default

Note: After 31 Mar 2027, Microsoft Sentinel is available only in the Microsoft Defender portal.

Architecture rabbit hole



Microsoft Sentinel — data lake & graph architecture

Every box is traceable to Microsoft Learn or to the endpoint-evidence figure sentinel-lake-graphs-endpoints.svg (extension 2.3.0 bundle, live MCP calls, portal HAR)

As of 2026-08-30

tenant PG · workspace Sentinel-NE

ACCESS SURFACES

Microsoft Defender portal
security.microsoft.com
Microsoft Sentinel ▸ Graphs · incident graph · hunting

Visual Studio Code — Sentinel extension
ms-security.ms-sentinel 2.3.0
Lake tables · notebooks · jobs · Graphs view

MCP clients
VS Code · Security Copilot · Copilot Studio · Foundry
Microsoft Entra identity · bearer token per request

Python SDK inside notebooks and jobs
sentinel_lake · sentinel_graph
PySpark DataFrames · GQL · GraphFrames

DATA SOURCES INGESTED INTO THE LAKE

Microsoft Defender XDR
Endpoint · Identity · Office 365 · Cloud Apps
Defender for Cloud

Microsoft Entra ID
Sign-in and audit logs
Entra ID Assets connector (asset tables)

Azure Resource Graph
Subscriptions, resource groups, resources
Azure Resource Graph connector (asset tables)

Microsoft 365 and Azure
All existing Microsoft Sentinel connectors
Threat intelligence

Third-party sources
EDR · firewall · network · DNS · proxy
Cloud infrastructure and workload telemetry

DATA LAKE — STORAGE TIERS, COMPUTE AND ANALYTICS ENGINES

ANALYTICS TIER (hot)

Log Analytics workspace · real-time detection, alerting and incident management · full Microsoft Sentinel feature set

Advanced hunting
KQL over hot data
High-performance queries

Rules and alerts
Detections · incidents
Workbooks · playbooks

Analytics retention
30 days by default
Extendable to 2 years

ExposureGraph tables
ExposureGraphNodes / Edges
same node ids as the graph →

EKG tables → graph

mirrored — a single copy of the data

DATA LAKE TIER (cold)

Open-format Parquet · cost-effective retention up to 12 years · storage separated from compute · multiple analytics engines

Security and activity tables
Mirrored from the analytics tier
Queried with KQL jobs, notebooks
and summary rules

Asset tables
Entra ID assets · Azure Resource
Graph · snapshot every 24 hours
feeds the identity attack graph →

Custom tables
Written back by notebooks
and Spark jobs
for example «_SPRK» output tables

auto-provisioned

read with PySpark or KQL

MANAGED APACHE SPARK COMPUTE

Three runtime pools chosen per notebook or job · vCore utilisation is shown in the VS Code status bar

Small
Development, testing and light
exploratory analysis

Medium
ETL with joins and aggregations,
ML model training

Large
Deep learning, extensive shuffles
and large joins

From the 2.3.0 bundle: default kernel MSGSmall · session kinds NotebookInteractive | GraphInteractive · poolType NotebookJob | GraphJob

Spark → custom graphs

ANALYTICS ENGINES

The same single copy of data is reachable from KQL, Python notebooks and AI agents

KQL
Interactive queries, KQL jobs,
scheduled and summary rules

Jupyter notebooks
PySpark with the
MicrosoftSentinelProvider class

Sentinel MCP server
Natural-language access to the
lake and to graph tools

MICROSOFT SENTINEL GRAPH — UNIFIED GRAPH ANALYTICS ACROSS DEFENDER AND PURVIEW

Nodes and edges over assets, identities, activities and threat intelligence · supports pre-breach and post-breach scenarios

PREDEFINED GRAPH — TURNED ON IN THE DEFENDER PORTAL

Identity attack graph (preview)

WHAT IT MODELS
How identities reach Azure resources through permissions
Nodes · users, service principals, managed identities,
groups, subscriptions, resource groups, VMs, storage
Edges · role assignments and group memberships

SET UP AND QUERY
Defender portal ▸ Microsoft Sentinel ▸ Graphs ▸ Set up graph
Connectors · Entra ID Assets + Azure Resource Graph
Roles · Global Administrator or Security Administrator
GQL · Schema tab, predefined queries, Run GQL query

Portal and GQL only — no /mcp route, so the find_* graph tools cannot query it (they target SystemScenarioEKGGraph).
PG tenant · checkTenant reports Predefined_Graph_IdentityAttack = Succeeded · initial processing can take up to 48 hours.

GRAPH EXPERIENCES IN DEFENDER XDR — AUTO-PROVISIONED WITH THE DATA LAKE

Incident graph + blast radius
Current impact of a breach and
possible future impact in one
consolidated graph
aka.ms/sentinel/graph/docs/incidents

Hunting graph
Interactively traverse relations
between users, devices and other
entities to reveal access paths
aka.ms/sentinel/graph/docs/hunting

Attack path analysis
Microsoft Security Exposure
Management and Defender for
Cloud · proactive attack-surface
management, critical assets

MICROSOFT PURVIEW GRAPHS — POWERED BY THE SAME GRAPH ANALYTICS

Data risk graph — Insider Risk Management
Map user activity to detect data exfiltration patterns
Understand the data-leak blast radius of risky activity
PG tenant · Graph_IRM eligible but not provisioned

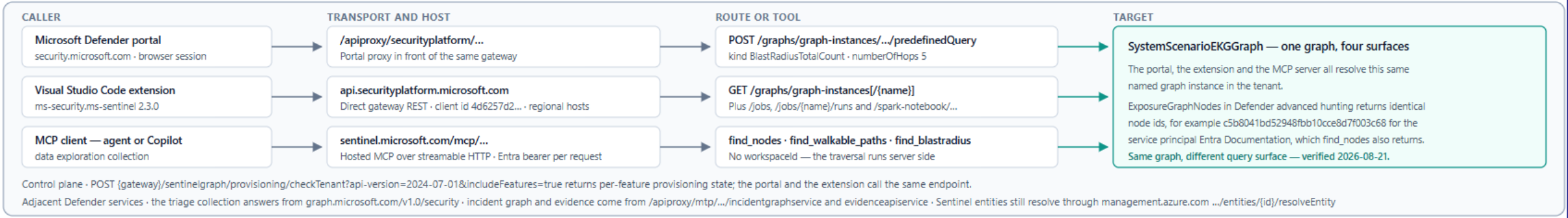
Data risk graph — Data Security Investigations
Trace sensitive data access and movement
Map exfiltration paths and understand breach scope
PG tenant · Graph_DSI provisioned (Succeeded)

CUSTOM GRAPHS AND PROGRAMMATIC ACCESS

Custom graphs (preview)
Authored in VS Code notebooks with sentinel_graph
Materialised in the tenant by a graph job
Queried and visualised with GQL in the Defender portal
On-demand graph jobs retain the graph for 30 days
Creation and queries bill the Sentinel graph meter

MCP graph tools — data exploration collection
Default graph · SystemScenarioEKGGraph
get_graph_context · find_nodes · find_connected_nodes
find_walkable_paths · find_blastradius
find_exposure_perimeter
No workspaceId, no time window · preview and metered

HOW EACH SURFACE REACHES THE GRAPH — CALLER, TRANSPORT, ROUTE, TARGET



VERIFIED CALL PATHS AND ENDPOINTS

Hosted MCP — Streamable HTTP, Entra auth

`https://sentinel.microsoft.com/mcp`

`/data-exploration · /triage`

`/security-copilot-agent-creation`

`/custom/<collection>`

Graph traversal runs server-side; the client never calls a graph API directly. query_lake needs a workspaceId.

Gateway REST — VS Code extension

`https://api.securityplatform.microsoft.com`

`GET /graphs/graph-instances[/{name}]`

`/jobs · /jobs/{name}/runs · /jobs/details`

`/spark-notebook/compute/sparkspecs`

`wss://…/api/kernels/{id}/channels`

Client id 4d6257d2-8e40-4f75-8da7-9cc73eab0764

Defender portal — browser calls

`/apiproxy/securityplatform/… same gateway`

`POST …/SystemScenarioEKGGraph/predefinedQuery`

`kind BlastRadiusTotalCount · numberOfHops 5`

`sentinelgraph/provisioning/checkTenant`

`/apiproxy/mtp/…/incidentgraphservice/{id}`

Portal, extension and MCP read one exposure graph.

PG tenant provisioning — checkTenant

Succeeded · Lake_USX, Graph_USX (+ optional)

Succeeded · Graph_DSI (+ optional)

Succeeded · Predefined_Graph_IdentityAttack

Eligible, not provisioned · Lake_Purview, Graph_IRM

accountLink · SDL-rg / msg-resources-5bc7 / northeurope

Triage plane answers from graph.microsoft.com/v1.0/security

Analytics tier · Data lake tier · Spark compute · Analytics engines · Microsoft Sentinel graph · Identity attack graph (preview) · Microsoft Purview graphs · Asset data feeding the identity attack graph

ExposureGraph KQL tables feeding the graph experiences · Lake onboarding provisioning the graph features · GraphInteractive Spark pool building custom graphs

Architecture – ISOC Workspace & Fabric

Microsoft Sentinel — data lake, graph and Fabric architecture

Part 1 of 2 · how each surface reaches the platform · every route shown was observed in portal and Fabric HAR captures, in MCP tool calls, or in the VS Code extension bundle

Traceable to Microsoft Learn and to the endpoint evidence in sentinel-lake-graph-architecture-v3-findings.md

tenant PG · workspace Sentinel-NE

a1822e45-cbde-4acf-8d8f-35f337623943

As of 2026-10-03

PLANE BOUNDARY

ACCESS SURFACES — who initiates the call

Microsoft Defender portal
security.microsoft.com

Microsoft Sentinel ▸ Graphs · incident graph
Advanced hunting over lake and XDR data
Browser session · calls routed via /apiproxy/

Visual Studio Code — Sentinel extension
ms-security.ms-sentinel 2.3.0

Lake tables · notebooks · jobs · Graphs view
Authors custom graphs and Spark jobs
Calls the gateway directly, not via the portal

MCP clients
agentic callers

VS Code Copilot · Security Copilot
Copilot Studio · Foundry
Entra bearer per request · role Security reader

Microsoft Fabric
app.fabric.microsoft.com

Spark notebooks · Power BI · Eventhouse
Reads Sentinel tables in place via OneLake
Separate identity and permission model

API PLANES — the gateway has two front doors · the triage collection has two data backends

Hosted MCP
sentinel.microsoft.com/mcp

```
/mcp/data-exploration /mcp/triage
/mcp/security-copilot-agent-creation
/mcp/custom/<collection>
/mcp/perception
mcp.svc.cloud.microsoft/enterprise
```

Streamable HTTP · Entra bearer per call.
Graph traversal runs server-side — the client never calls a graph API itself.
query_lake requires a workspaceId.

Security platform gateway
one service, two front doors

```
api.securityplatform.microsoft.com
└ VS Code extension, direct
/apiproxy/securityplatform/…
└ Defender portal, via proxy

graphs/graph-instances[/{name}]
sentinelgraph/provisioning/checkTenant
sentinelgraph/catalog/tables
lake/databases · lake/kql/v2/rest/query
jobs/details · billing-integration-service
```

Defender XDR services
portal-only incident and hunting APIs

```
/apiproxy/mtp/useServiceBaseUrl/ine/
incidentgraphservice/incidentGraph/{id}
evidenceapiservice/evidence/incident/{n}
/apiproxy/mtp/alertsApiService · incidents
/apiproxy/mtp/CaseManagement/be/…

/apiproxy/hunting/huntingService/
queryExecutor/huntingGraph
/apiproxy/medeina/sessions/query
└ Security Copilot inside the portal
```

Triage and telemetry backends
two Defender APIs, not one

```
graph.microsoft.com/v1.0/security
└ incidents · alerts · runHuntingQuery
api.securitycenter.microsoft.com/api
└ machines · files · vulnerabilities
remediation · logged-on users

api.loganalytics.io/v1/workspaces/{id}/query
└ portal reads the hot tier directly
management.azure.com …/resolveEntity
└ Sentinel entity resolution
```

Fabric and OneLake
OneLake data plane

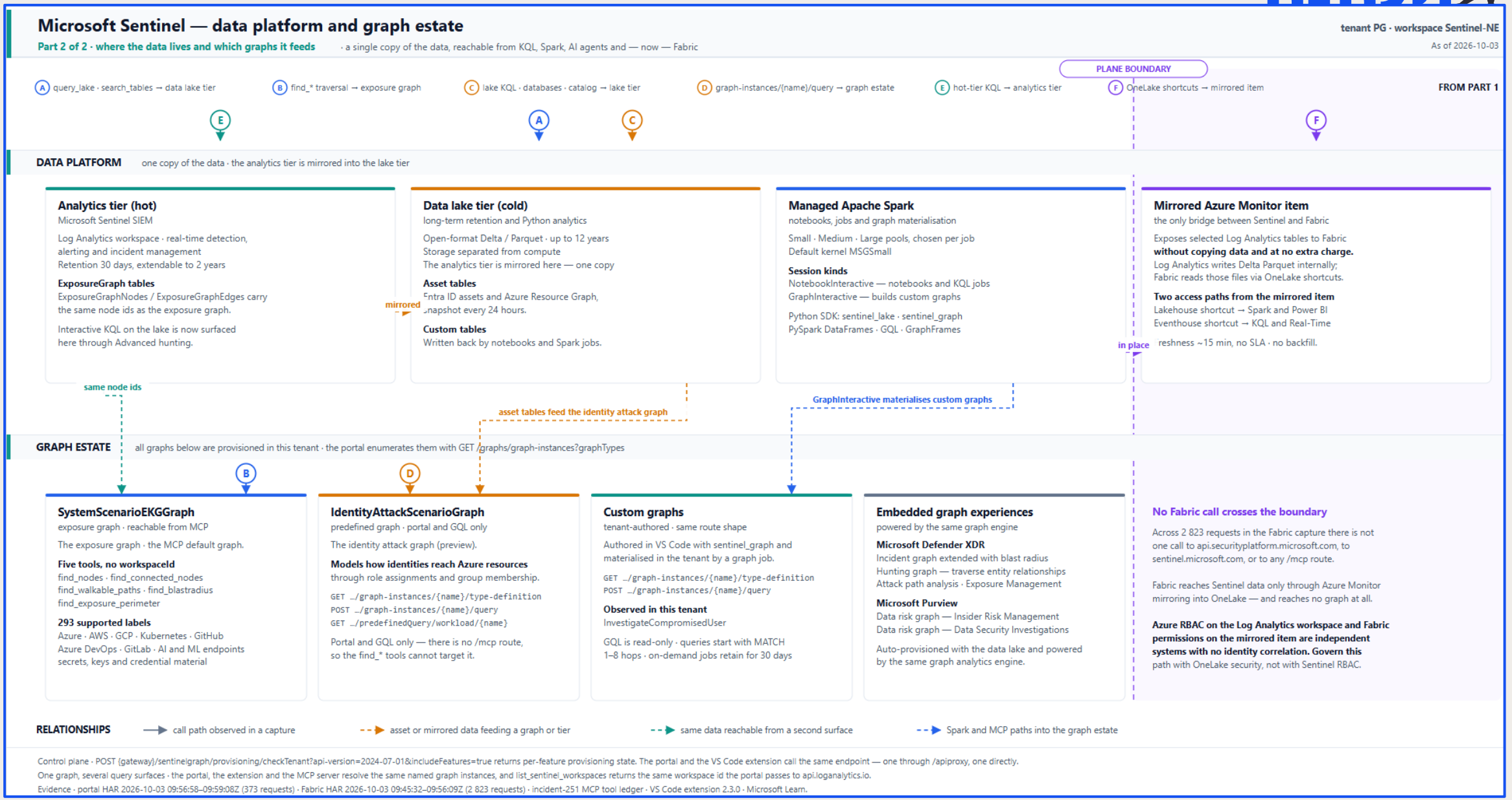
```
api.fabric.microsoft.com/v1/workspaces/
{ws}/items/{item}/shortcuts
onelake.dfs.fabric.microsoft.com/v1.0/
workspaces/{ws}/artifacts/{art}/query
…/artifacts/{art}/security/userAccess
onelake…/{ws}?getShortcutMetadata&recursive
```

Compute and reporting ride on `*.pbidedicated.windows.net (Spark)` and `*.analysis.windows.net (Power BI)`.
Sign-in via login.microsoftonline.com.

CONTINUES ON PART 2

Ⓐ query_lake · search_tables → data lake tier
Ⓑ find_* traversal → exposure graph
Ⓒ lake KQL · databases · catalog → lake tier
Ⓓ graph-instances/{name}/query → graph estate
Ⓔ hot-tier KQL → analytics tier
Ⓕ OneLake shortcuts → mirrored item

Architecture – ISOC Workspace & Fabric



Findings

Sentinel Cost – Data Lake

01 Commitment Tier

02 Data lake costs

Where the meters land

Analytics tier

Pay-as-you-go or commitment tier (from 100 GB/day) · pre-purchase plan eligible

01

Commitment tier and pre-purchase plan

Data lake tier — usage meters

02

Data lake ingestion	per GB · lake-only tables
Data processing	per GB · lake-only tables
Data lake storage	per GB/month · 6:1 compression
Data lake query	per GB scanned
Advanced data insights	per compute hour

Findings

Data Exploration MCP

1. MCP tool collection is not available in the ISOC workspace

2. Sentinel extension in VS Code cannot access the data lake



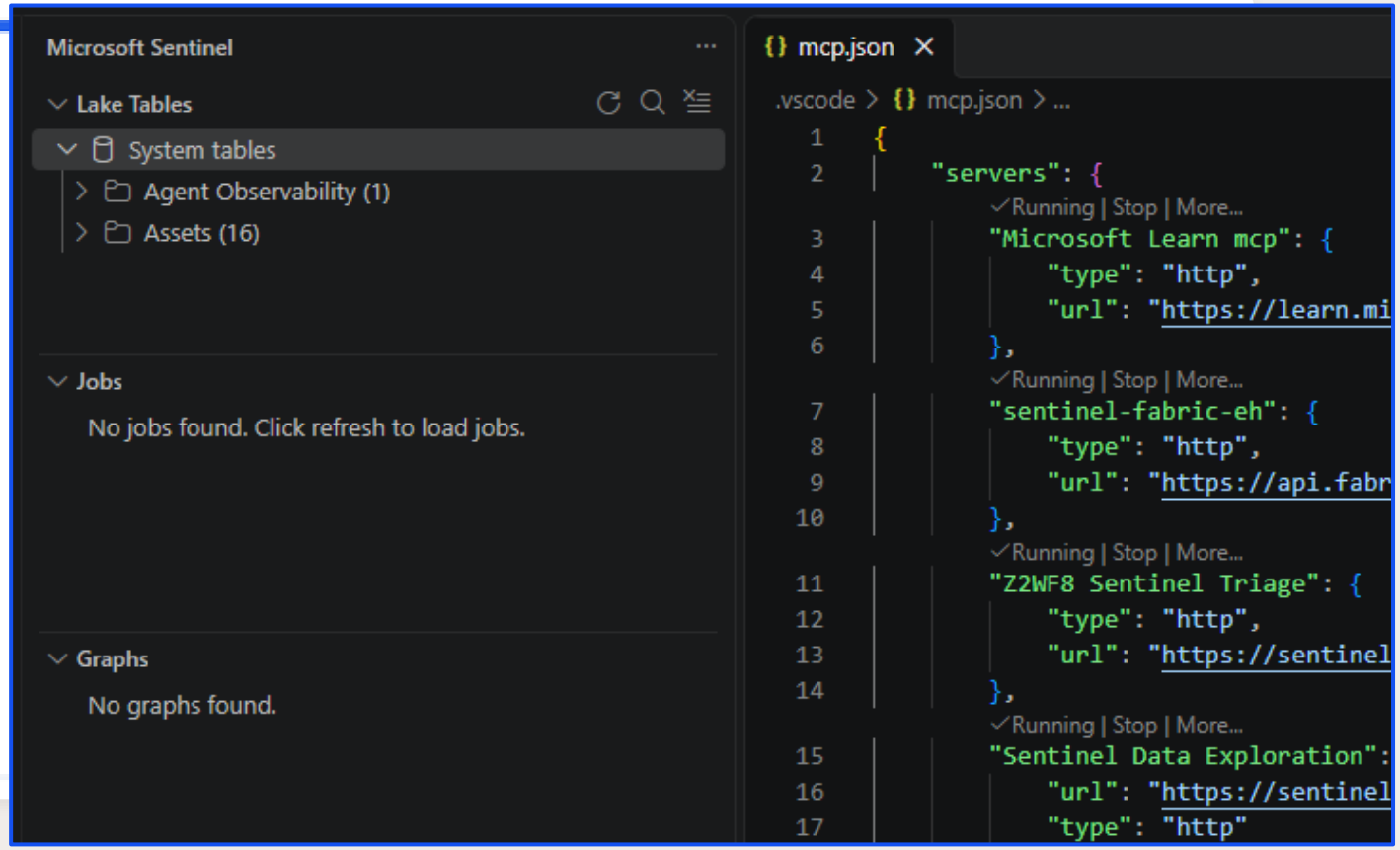
Hosted MCP

sentinel.microsoft.com/mcp

1 /mcp/data-exploration /mcp/triage
/mcp/security-copilot-agent-creation
/mcp/custom/<collection>
/mcp/perception
mcp.svc.cloud.microsoft/enterprise

Streamable HTTP · Entra bearer per call.
Graph traversal runs server-side — the client never calls a graph API itself.

1 query_lake requires a workspaceId.



Findings

ISOC Workspace & Advanced Analytics

1. Fabric MCP endpoints need to be enabled separately

2. Available through Fabric Eventhouse MCP



No Fabric call crosses the boundary

Across 2 823 requests in the Fabric capture there is not one call to api.securityplatform.microsoft.com, to sentinel.microsoft.com, or to any /mcp route.

1

Fabric reaches Sentinel data only through Azure Monitor mirroring into OneLake — and reaches no graph at all.

Azure RBAC on the Log Analytics workspace and Fabric permissions on the mirrored item are independent systems with no identity correlation. Govern this path with OneLake security, not with Sentinel RBAC.

Mirrored Azure Monitor item

the only bridge between Sentinel and Fabric

Exposes selected Log Analytics tables to Fabric **without copying data and at no extra charge.** Log Analytics writes Delta Parquet internally; Fabric reads those files via OneLake shortcuts.

Two access paths from the mirrored item

Lakehouse shortcut → Spark and Power BI

Eventhouse shortcut → KQL and Real-Time

2

SECURITY NINJA GERMANY

Sentinel Data Lake Powered Graphs



Microsoft Sentinel Data Lake Powered Graphs

One graph, surfaced everywhere

Built-in graph experiences across Defender and Purview

Defender XDR

Incident graph

Blast radius of a breach in one consolidated view

Defender XDR

Hunting graph

Traverse hidden relationships between assets

Sentinel Data lake

Purview · Insider Risk Management

Data risk graph

Map user activity to spot exfiltration patterns

Retiring by Nov 24, 2026

Purview · Data Security Investigations

Data risk graph

Trace sensitive data access and movement

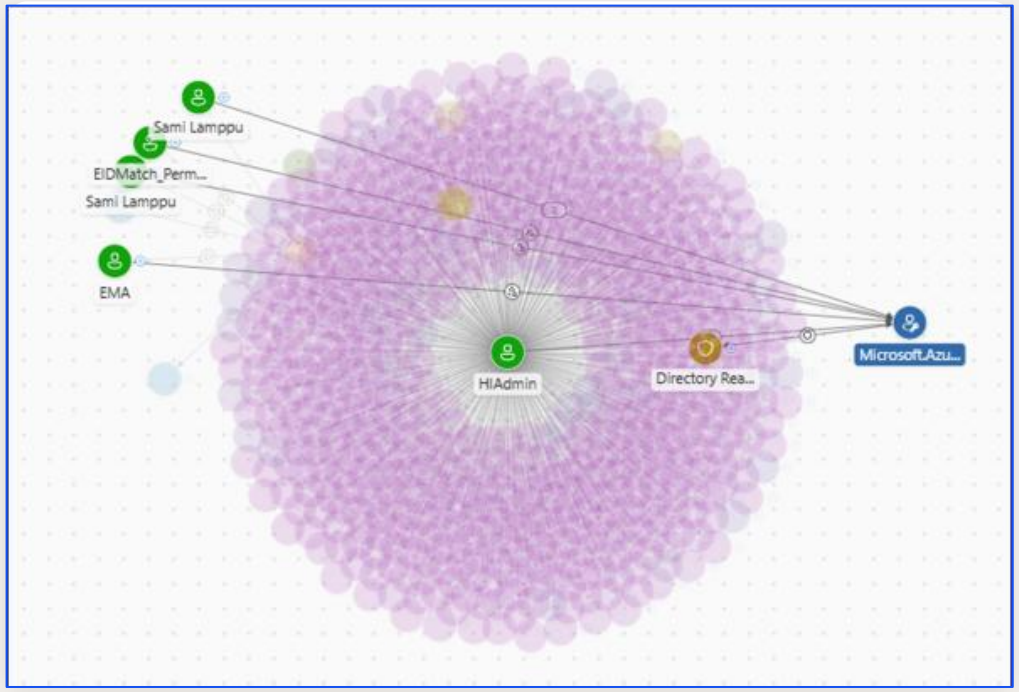
Retiring by Nov 30, 2026

Defender XDR: Exposure Management

Enterprise exposure graph (MSEM)

Separate graph, same attack-path story

New kid on the block: Identity Attack Graph

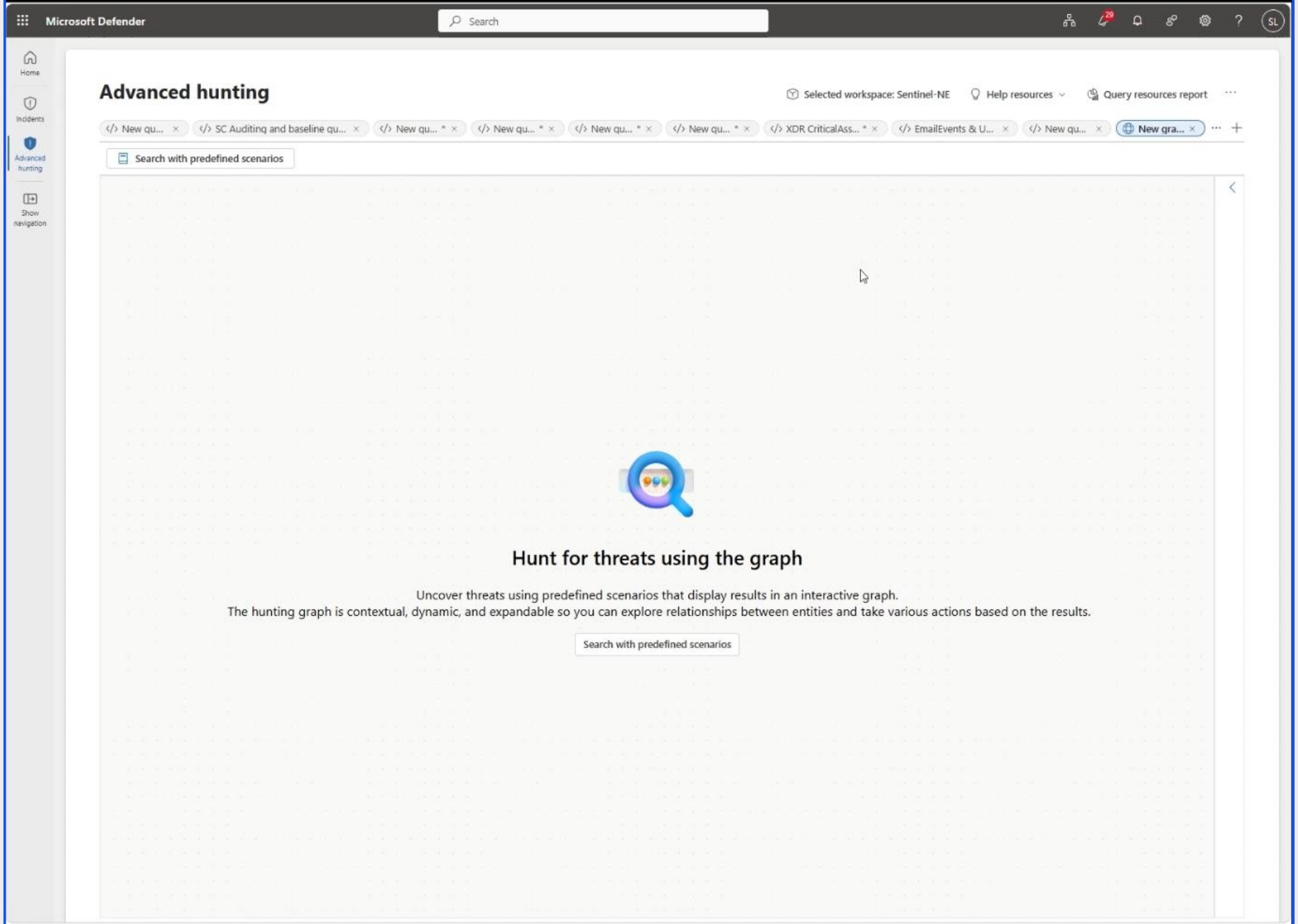


Maps how identities, permissions, and trust relationships can be exploited to move laterally and escalate privileges — scoped to Azure and Entra

Demo: Graph-powered hunting

Graph-powered hunting through Defender advanced hunting that leverages data from the Sentinel data lake





SECURITY NINJA GERMANY

Identity Attack Graph vs Exposure Graph

Home
Incidents
Advanced hunting
Hide navigation

Find Defender solutions

Home
Cases New
Exposure management
Overview
Secure now
Initiatives
Recommendations
Vulnerability management
Attack surface
Attack paths
Map
Secure score
Data connectors
Investigation & response
Threat intelligence
Assets
Microsoft Sentinel
Identities
Endpoints
Email & collaboration
Cloud apps
Cloud security
Security Copilot
SOC optimization
Reports
Learning hub
Trials
More resources

Home

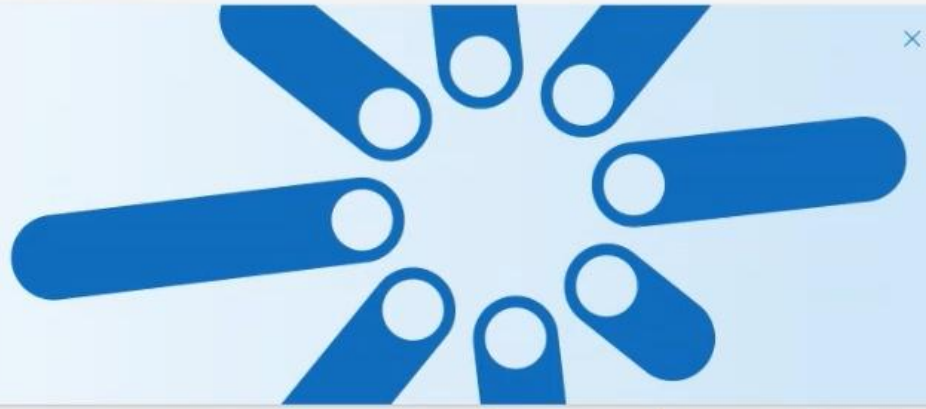
Dark mode

Your unified SIEM and XDR is ready

Everything you need is now in one place. You can now hunt, investigate, and respond faster with full attack context across both SIEM and XDR.

Start hunting

Learn about unified SIEM and XDR experiences



Guided tour | What's new? | Community | Add cards

Entity Behavior Analytics (UEBA)

Workspace: Sentinel-NE

1 anomalies in the last 14 days

Top anomalies by type in the last 14 days

1 Anomalous Azure operations

Data sources

Data sources with UEBA enabled

7/12

Suggested hunting queries

View all users with anomalies from the last 14 days

View all anomalies from the last 14 days

SOC optimization

Your optimization data

Optimization status

Active	In progress	Completed	Dismissed
37	0	93	0

Recent optimization value

You improved your coverage against BEC (Mass Credential Harvest) attacks.

Utilized AlertInfo table and improved your SOC coverage.

Microsoft Sentinel data connectors

8 data connectors

Last 24 hours

Active connectors	Unhealthy connectors
8/8	0/8

TI by type (0)

Data received



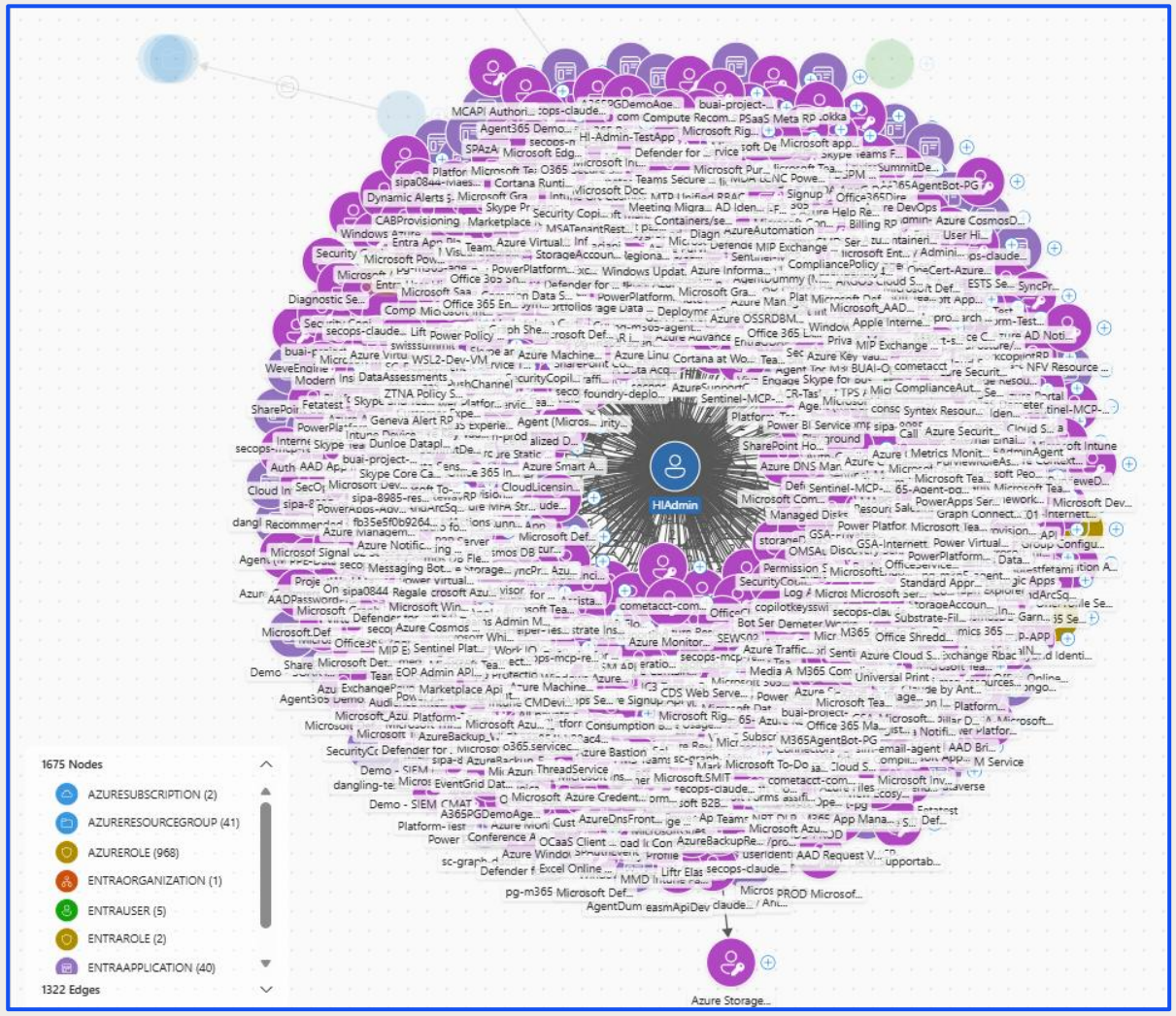
Identity Security Deployment Status

Defender protects your identities with posture security recommendations and threat protection.
Learn more

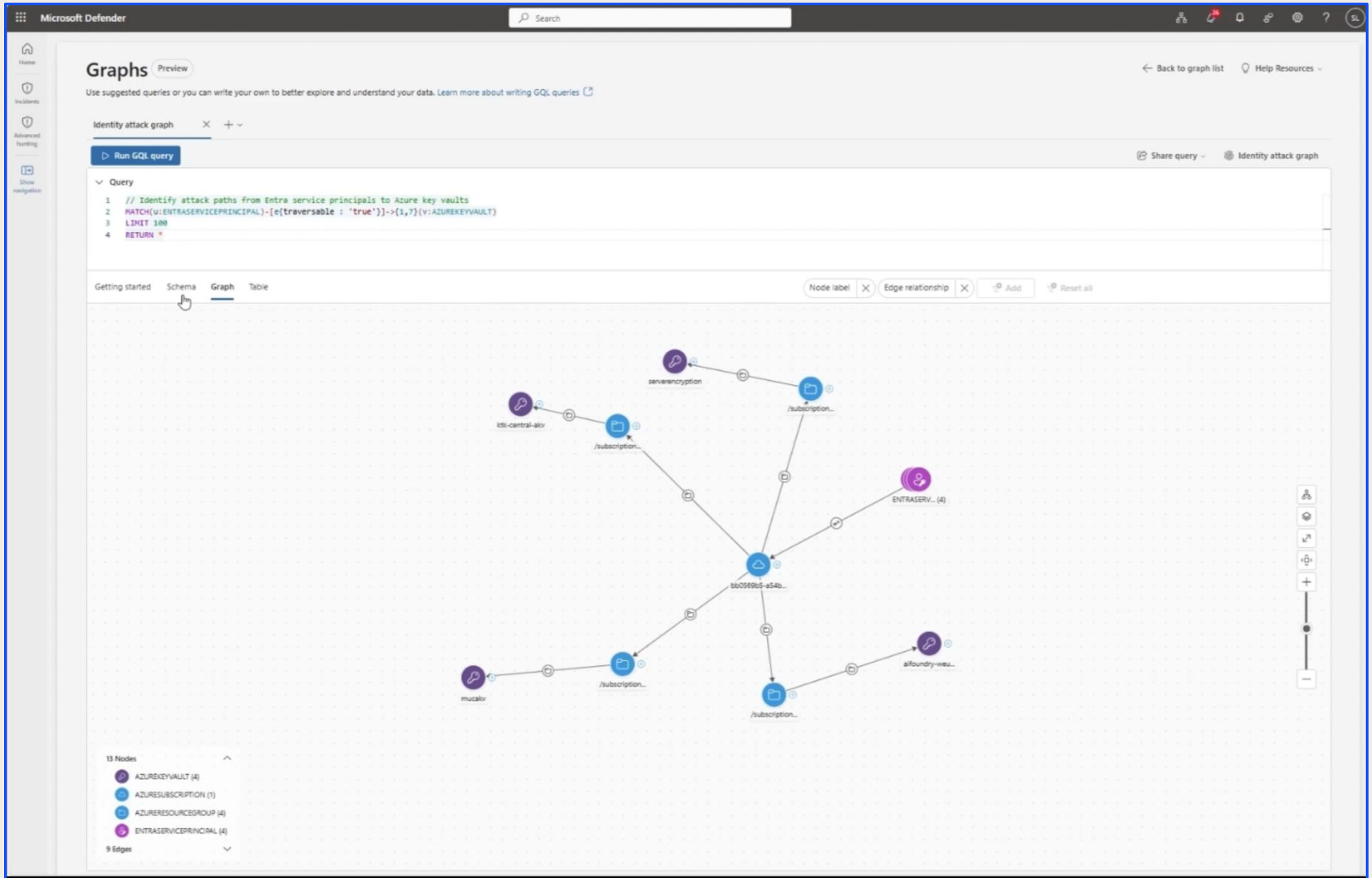
Protected	Needs Attention	Not Protected
4	0	7

Sentinel – Identity Attack Graph

- The identity attack graph in Microsoft Sentinel visualizes how identities connect to Azure resources through permissions and group memberships
- Graph uses asset data from the Sentinel lake's Entra ID asset and Azure resource graph connectors
- Assets:
  - Identities
  - Azure resources
  - Access and permission relationships



Sentinel – Identity Attack Graph



Identity Attack Graph vs. Enterprise Exposure Graph (MSEM)

Dimension	Identity Attack Graph	Enterprise Exposure Graph
Product / platform	Microsoft Sentinel **data lake** (in Defender portal → Sentinel → Graphs)	Microsoft **Security Exposure Management** (Defender portal → Exposure Management)
Primary focus	Identity-centric: how identities reach Azure resources via permissions, roles, group memberships	Enterprise-wide attack surface: assets, exposure, vulnerabilities, and attack paths across the whole estate
Data sources	Entra ID Assets connector + Azure Resource Graph connector (data lake)	Broad device/identity/cloud/SaaS signal from Defender (XDR, MDE, MDC, Entra, multi-cloud AWS/GCP, etc.)
Entity scope	Identities (users, SPs, managed identities, groups) + Azure subscriptions/RGs/resources	Very broad: devices, identities, cloud resources, secrets, SaaS, AI resources, network components, credentials
Query interface	**GQL** (Graph Query Language) — write custom or use predefined queries	Predefined analytics + **KQL** over ExposureGraphNodes/ExposureGraphEdges; MCP graph tools

Identity Attack Graph vs. Enterprise Exposure Graph (MSEM)

Dimension	Identity Attack Graph	Enterprise Exposure Graph
Access method	Portal GQL experience today; **no direct MCP/GQL tool**	Portal and MCP tools (find_connected_nodes, find_walkable_paths, find_blastradius, find_exposure_perimeter, find_nodes) + Advanced Hunting KQL
Setup / prerequisites	Sentinel data lake enabled; turn on graph (Global/Security Admin); up to 48h initial build	Enabled with Exposure Management; no separate graph build step
Output shape	Discrete, fully-enumerated paths	Node set + edges (reconstruct paths client-side); ranked exposure/risk context
Automation / agents	Limited to portal today	Automation via MCP + KQL; good for Copilot/agent workflows
Best for	Precise identity privilege-path analysis in Azure/Entra from data-lake truth	Cross-domain blast radius, internet exposure, "what can an attacker reach," posture prioritization

Summary of Sentinel-Powered Graph(s)

Where each graph lives, when to use it, and the value it delivers

GRAPH	WHERE IT LIVES	BEST-FIT SCENARIO	VALUE
Incident graph (Blast Radius)	Defender XDR: Incident page	Active incident triage: trace blast radius from a compromised entity to critical assets	Consolidated current + future impact view, scoped to the analyst's permissions
Hunting graph	Defender XDR: Advanced Hunting	Proactive hunting via MITRE-mapped predefined scenarios or KQL graph-match	No-code discovery of hidden paths and choke points across users, devices, assets
Identity attack graph (preview)	Microsoft Sentinel: Graphs page	"What can an attacker reach if this identity is compromised?" across Azure + Entra	GQL-queryable lateral-movement / privilege-escalation paths, identity-scoped
Custom graphs (preview)	Microsoft Sentinel: Graphs page (authored via VS Code + Jupyter) + **Fabric**	Bespoke scenarios or non-Microsoft data sources not covered by built-in graphs	Bring-your-own-data graph modeling that gives AI agents extra context
Data risk graph: Purview IRM (deprecated 10/2026)	Microsoft Purview: Insider Risk Management	Risky-user investigation across SharePoint / OneDrive activity	Maps user activity to exfiltration patterns and data-leak blast radius
Data risk graph: Purview DSI (deprecated 10/2026)	Microsoft Purview: Data Security Investigations	Scoping a confirmed breach or investigation	Traces sensitive-data access/movement and exfiltration paths
Enterprise exposure graph *(related, separate)*	Microsoft Security Exposure Management, queried via Advanced Hunting	Ad hoc KQL posture analysis across the whole attack surface	Same attack-path story, but not part of the "Sentinel graph" brand

SECURITY NINJA GERMANY

Sentinel MCP Server



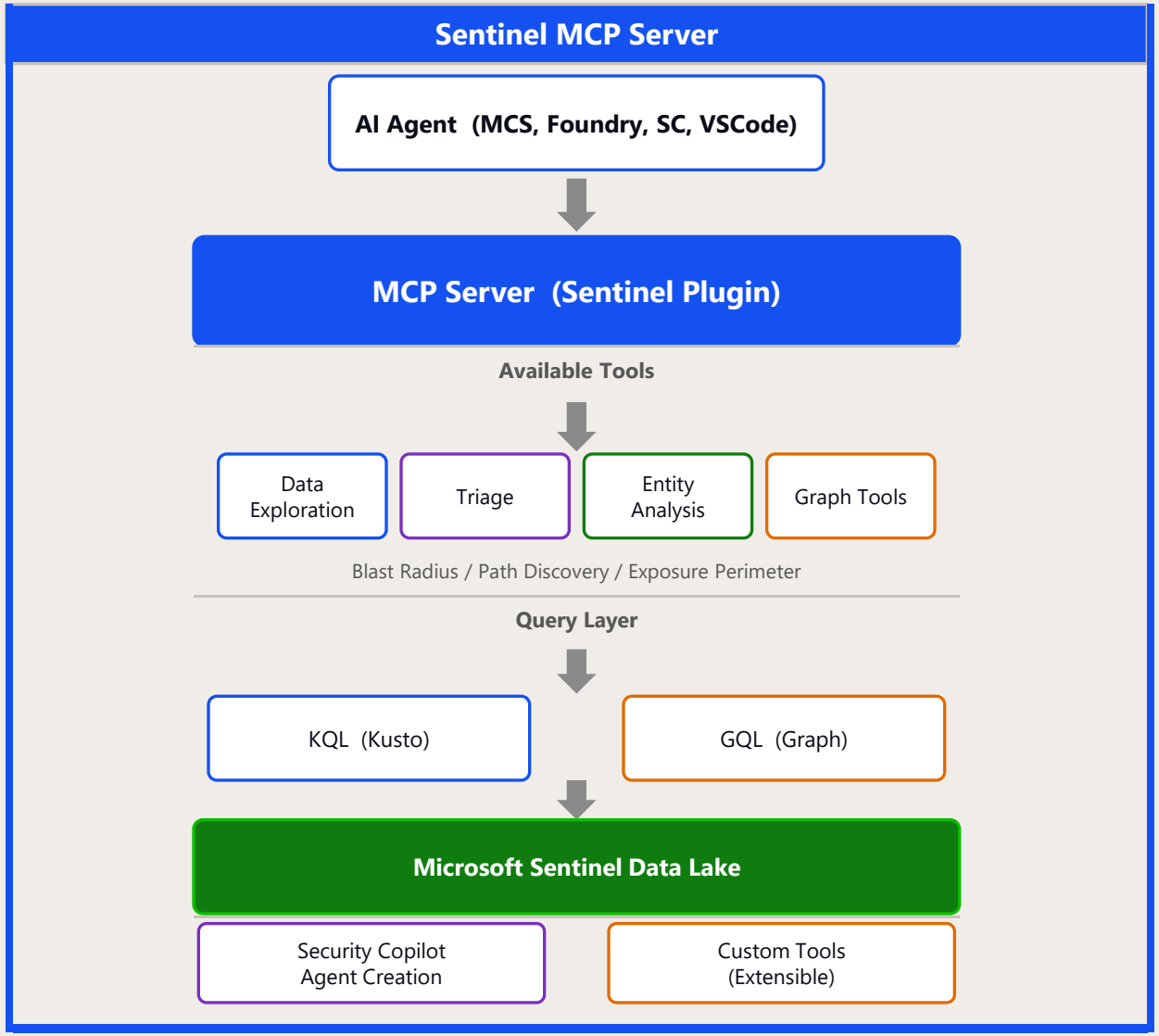
Sentinel MCP Server

Collection of tools, including:

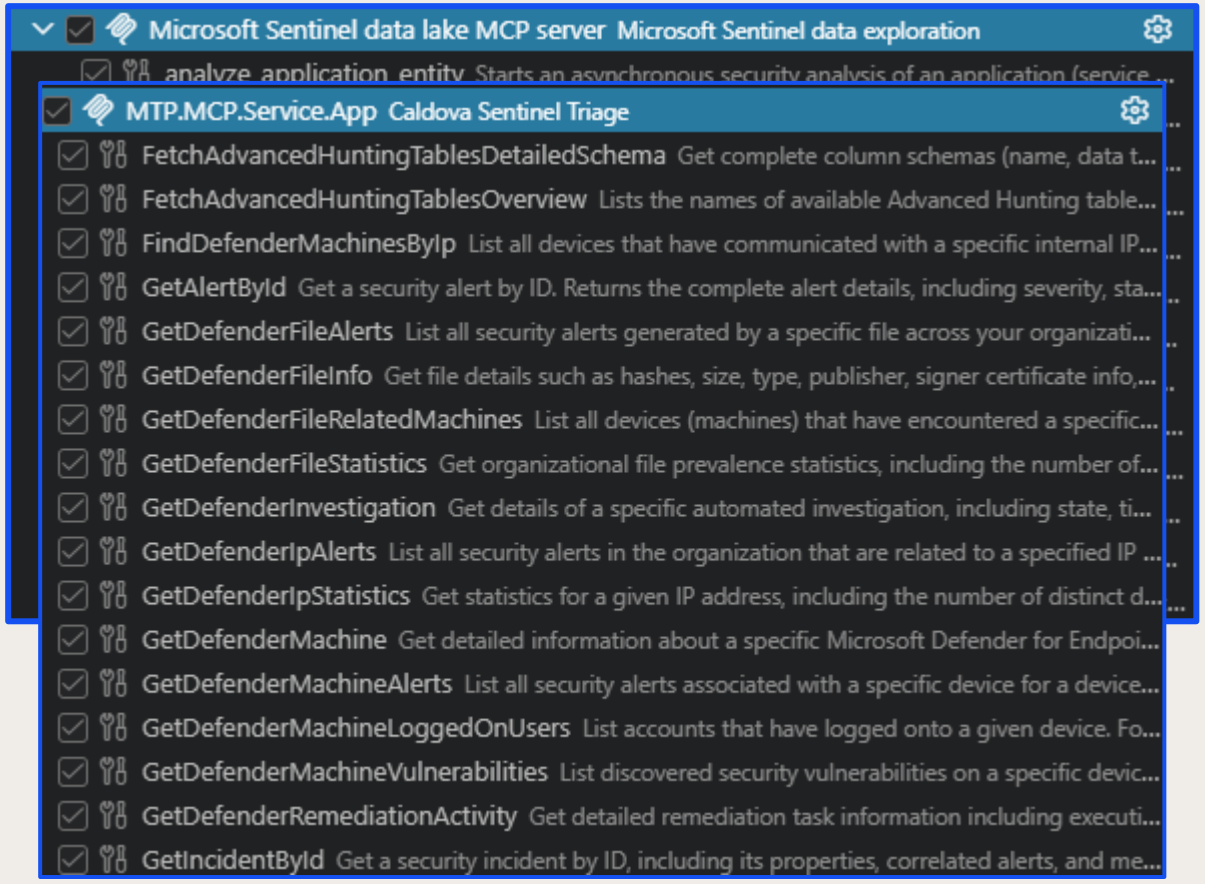
- Data Exploration
- Triage
- Entity Analyzer

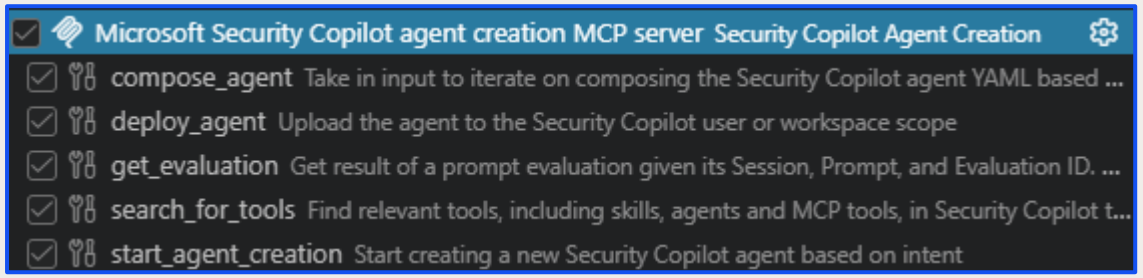
Graph tools such as:

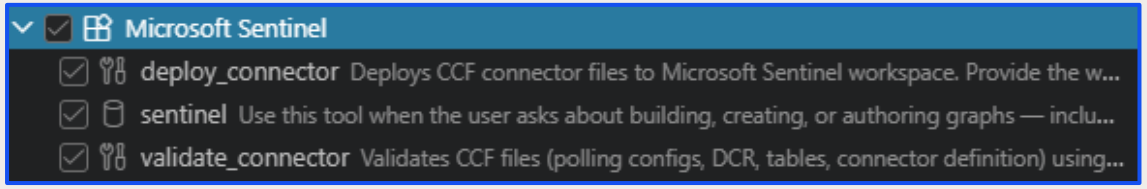
- Blast Radius, Path Discovery, Walkable Paths & Exposure Perimeter
- Security Copilot agent creation
- Possibility to add custom tools

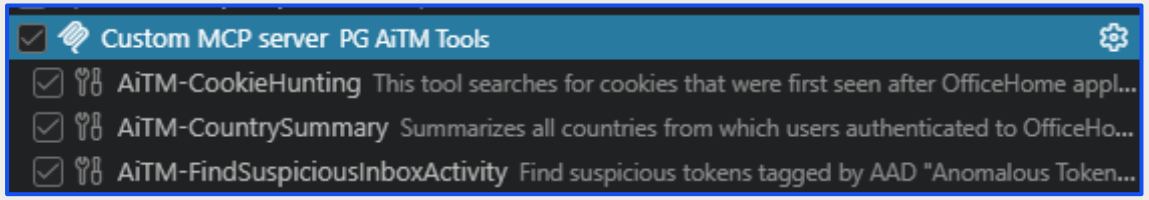


Sentinel MCP Tools









Demo: Graph-powered investigation & Blast Radius with MCP

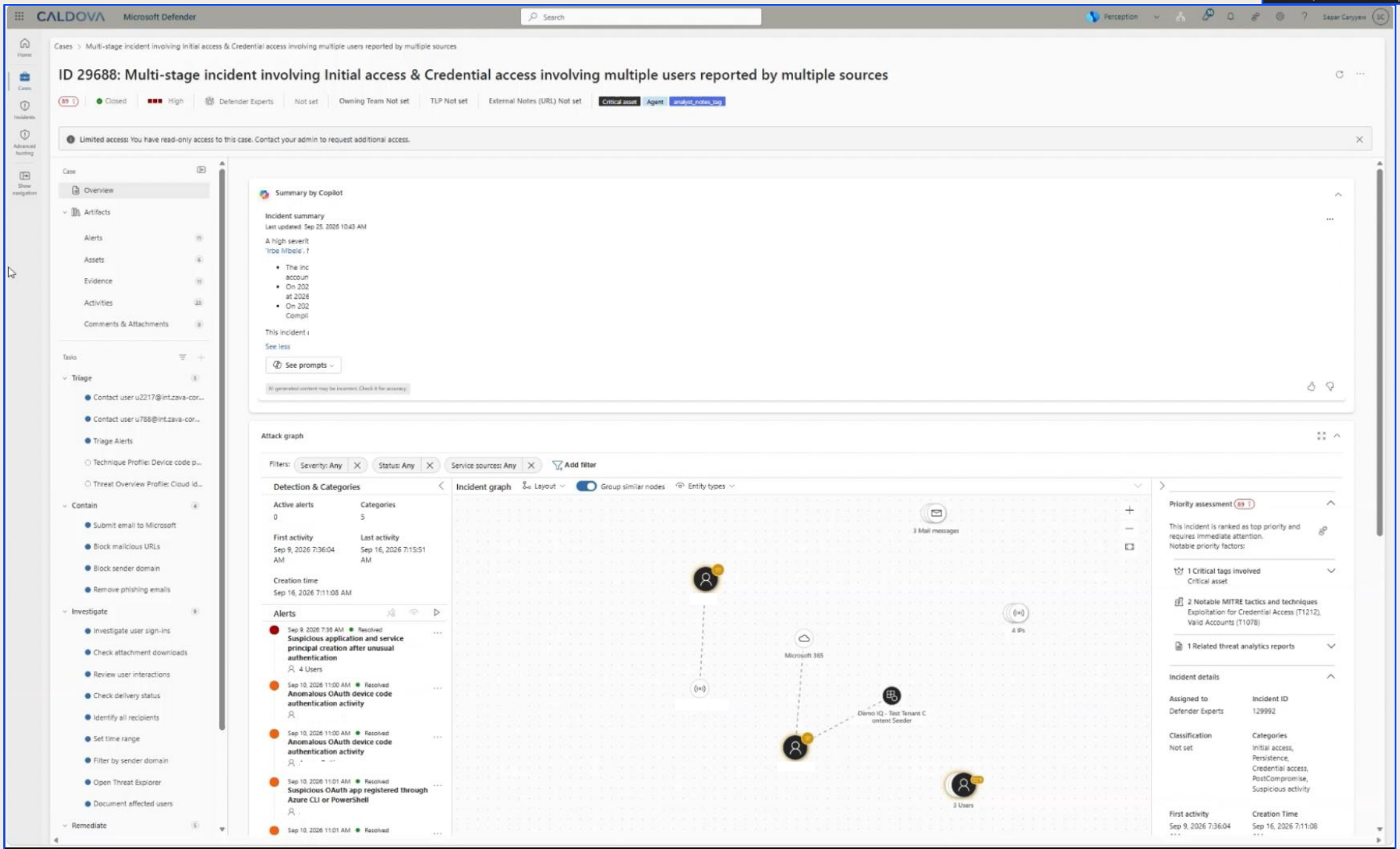
SECURITY NINJA GERMANY

Evaluating blast radius from the Defender portal & through Sentinel MCP server



Blast Radius – Portal & MCP

Evaluate the Blast Radius of a node or group of nodes by considering valid entrypoints, targets, and the connections between them. The Blast Radius indicates the potential impact on the environment if a node is compromised. Nodes with a high Blast Radius represent significant risks as their compromise could lead to widespread damage and disruption, requiring prioritized protection and monitoring. Examples of what you can do with it: 1. Find a blast radius of Sam? 2. What's the scope of impact if user Sam is compromised? 3. If user Sam is breached, what would be the potential impact?



Sentinel MCP – Blast Radius

Evaluate the Blast Radius of a node or group of nodes by considering valid entrypoints, targets, and the connections between them. The Blast Radius indicates the potential impact on the environment if a node is compromised. Nodes with a high Blast Radius represent significant risks as their compromise could lead to widespread damage and disruption, requiring prioritized protection and monitoring. Examples of what you can do with it: 1. Find a blast radius of Sam? 2. What's the scope of impact if user Sam is compromised? 3. If user Sam is breached, what would be the potential impact?

```
1   # Executive Summary – Security Investigation
2
3   ## Incident 129992 – Mult
4
5   | | |
6   |---|---|
7   | **Incident ID** | [1299
    tid=0527ecb7-06fb-4769-b3
8   | **Title** | Multi-stage
    reported by multiple sour
9   | **Severity / Priority**
10  | **Status** | Resolved (
11  | **Owner** | Defender Ex
12  | **Window** | 2026-09-16
13  | **Correlated alerts** |
14  | **Report date** | 2026-
15
16  > **Environment note:** T
    alerts were closed as *fa
    (Security Copilot Sentry)
17
```

Incident 129992 — Multi-stage Identity Compromise

Attack chain · Severity High · Priority 89 · Resolved · Generated 2026-09-22

STAGE 1 · Initial Access
Device-code phishing
u2217 (Asm
Attacker IP
PowerShell 7.6.6
T1528 · T1078.004

STAGE 2 · Persistence
OAuth app + SP
App 95875379-...-c1d6
"Demo IQ Content Seeder"
Creds + ownership set
T1098 · T1136

STAGE 3 · Lateral Phishing
Internal mail sent
From
u408
"Your file is ready" ...
T1114

STAGE 4 · Credential Access
Account takeover
u78
IP 1
stin)
Suspicious MFA approval
T1078 · T1110 · T1539

STAGE 5
Recon
u7 utomation-like access to security tooling
T1078

Correlated alerts (11 across 5 sources)

- Anomalous OAuth device code auth — Med
- Suspicious OAuth app registration — Med
- App & service principal creation — High (SecCopilot)
- Security tooling access after unusual auth — High
- Potential account compromise ×3 — Med
- Unfamiliar sign-in properties — Med
- Suspicious MFA Authentication Approval — Low
- Sources: AADIP · XDR · DfI · DfCA · SecCopilot

Two high-severity alerts are AI-generated (Security Copilot Sentry) and require verification. Two OAuth alerts closed as false-positive.

Outcome & exposure

Compromised identities (both critical assets)

- u221 (origin/pivot)
- u7 ele (recon)

Shared blast radius — 47 resources, 1 permission hop

24	20	3
Critical Key Vaults	AI Foundry / Cognitive	Azure OpenAI

Both accounts share the exact same footprint → common subscription-scoped Azure RBAC "Reader" grant (inherited). Fix at the group, not per-user.

Primary containment: revoke tokens, remove OAuth app, review vault access + rotate secrets.

MITRE ATT&CK: T1078 · T1078.004 · T1528 · T1098 · T1136 · T1114 · T1110 · T1212 · T1539

Demo: NHI investigation with MCP

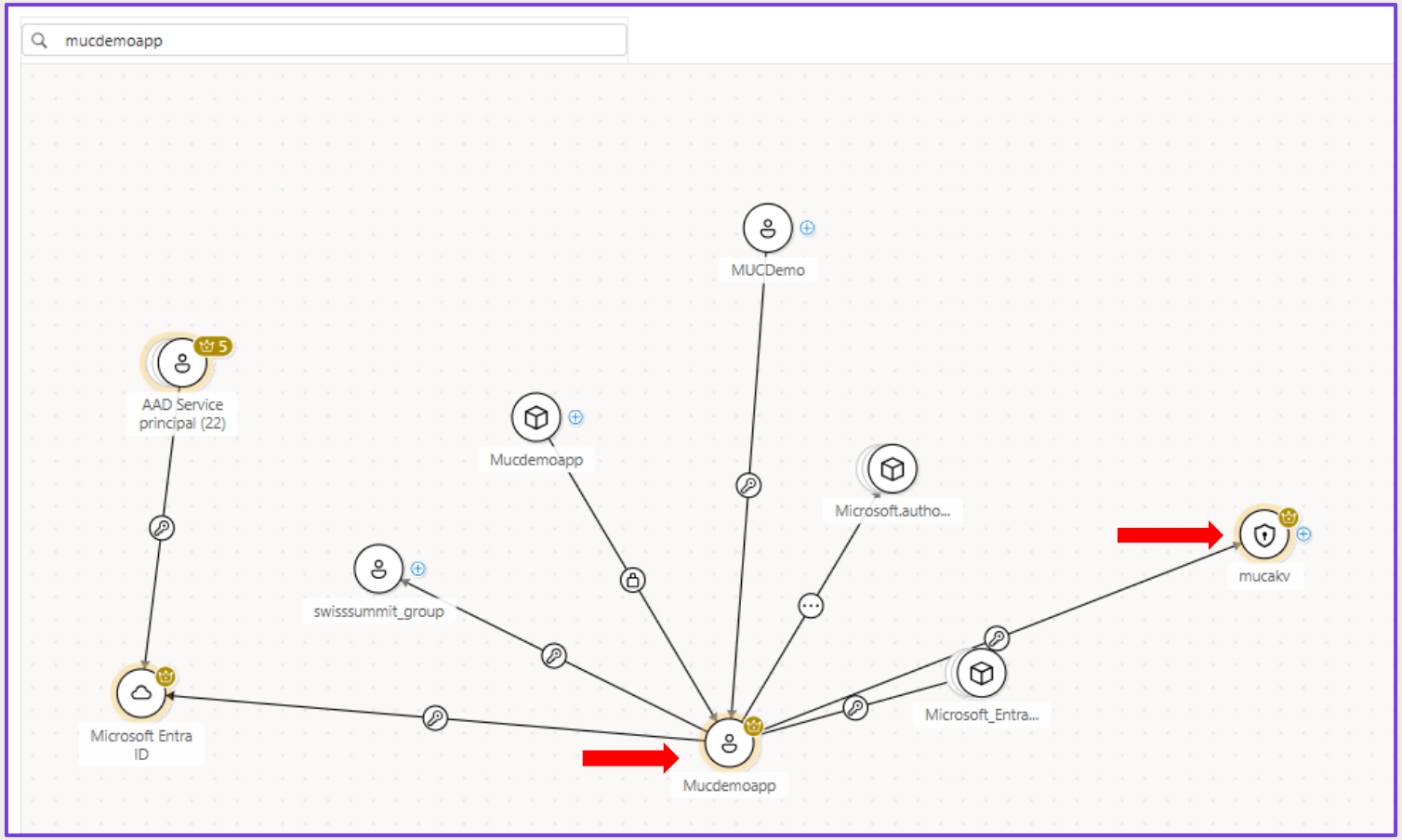
Walkthrough of Non-Human Identity investigation through Sentinel MCP server



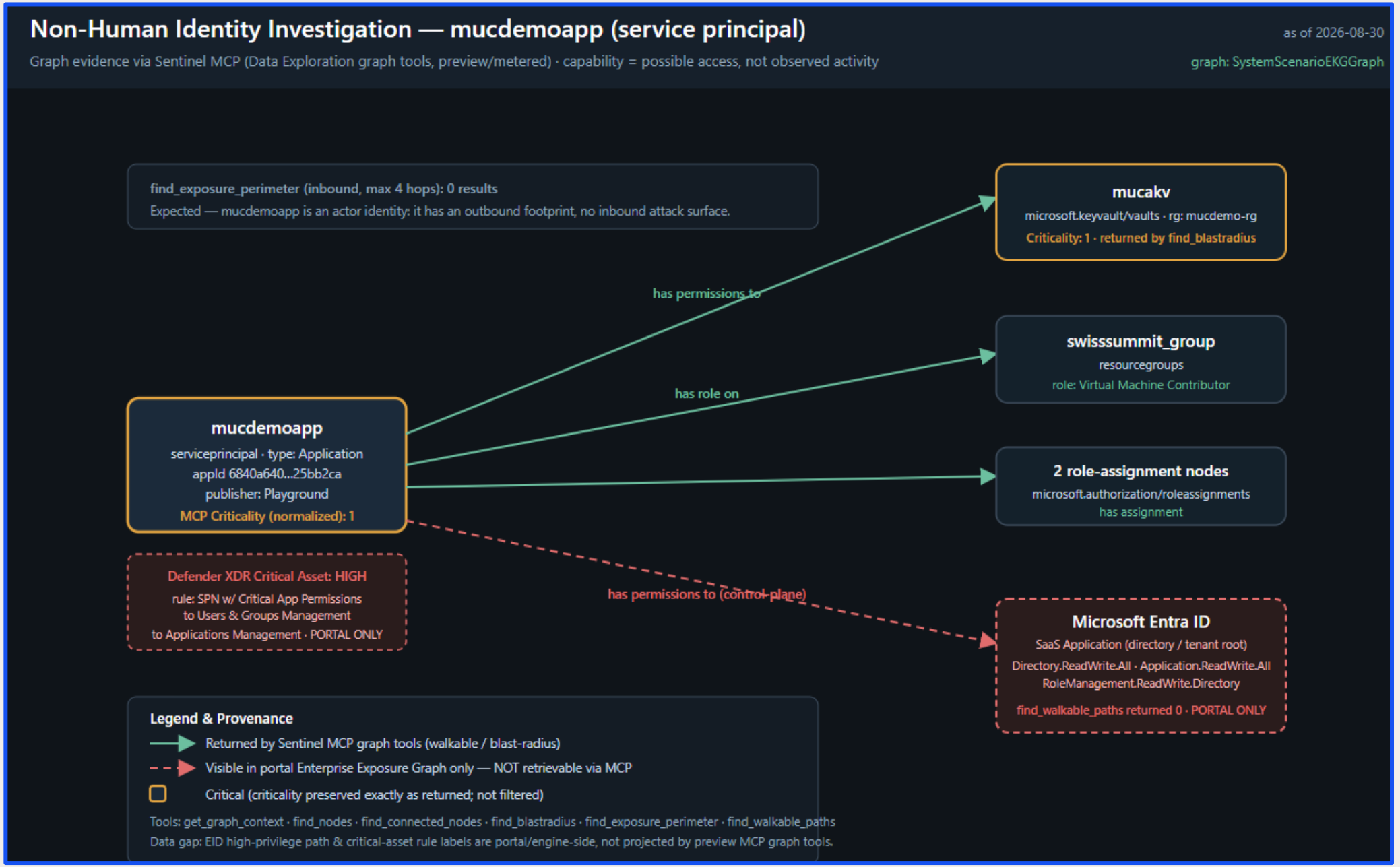
Enterprise Exposure Graph through Sentinel MCP – Is it possible?

Investigation flow:

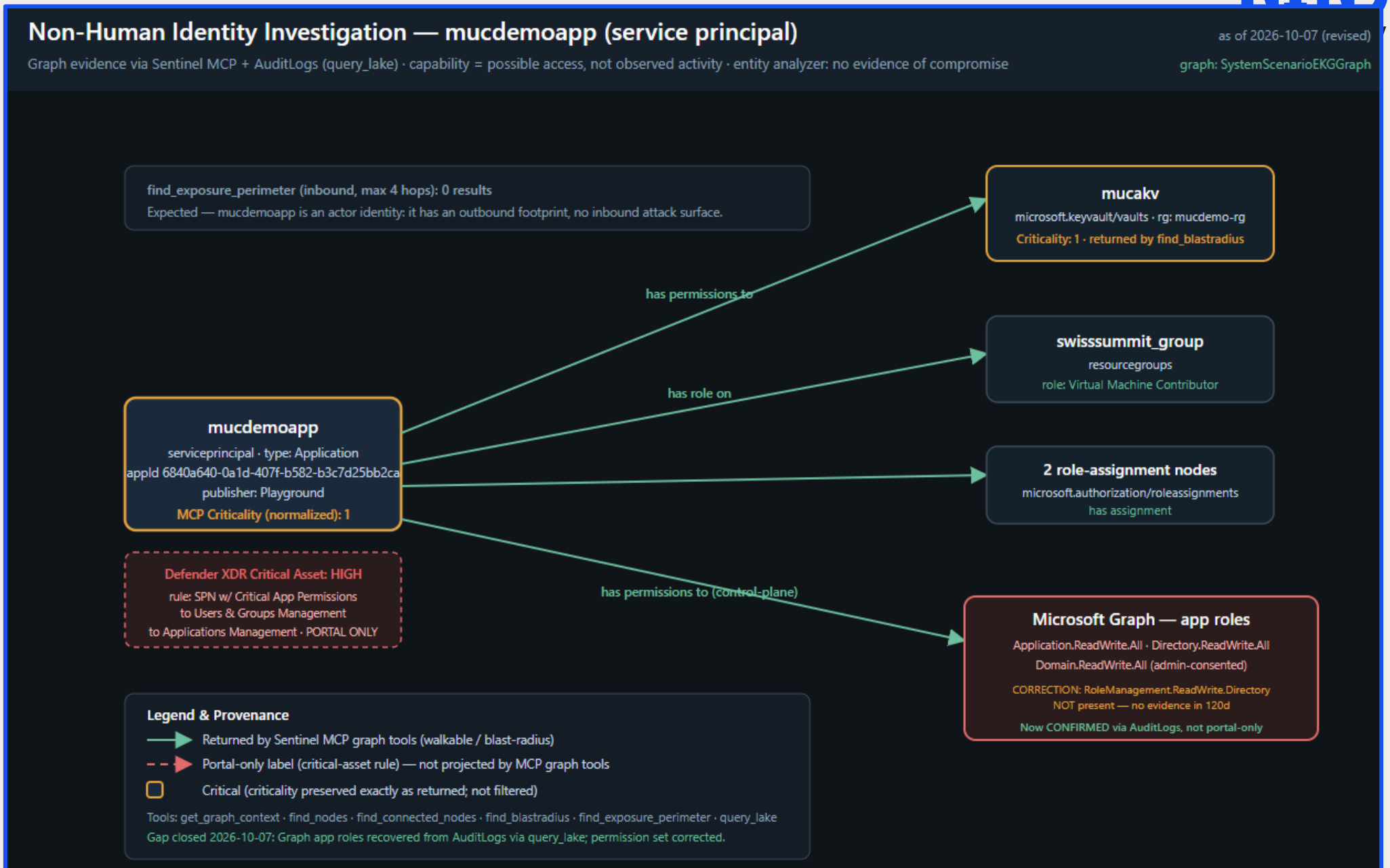
- Investigate NHI ‘mucdemoapp’ through MCP using graph tools
- Evaluate blast radius
- Leverage find_exposure_perimeter followed by find_connected_nodes
- At the end, draw an SVG of the findings



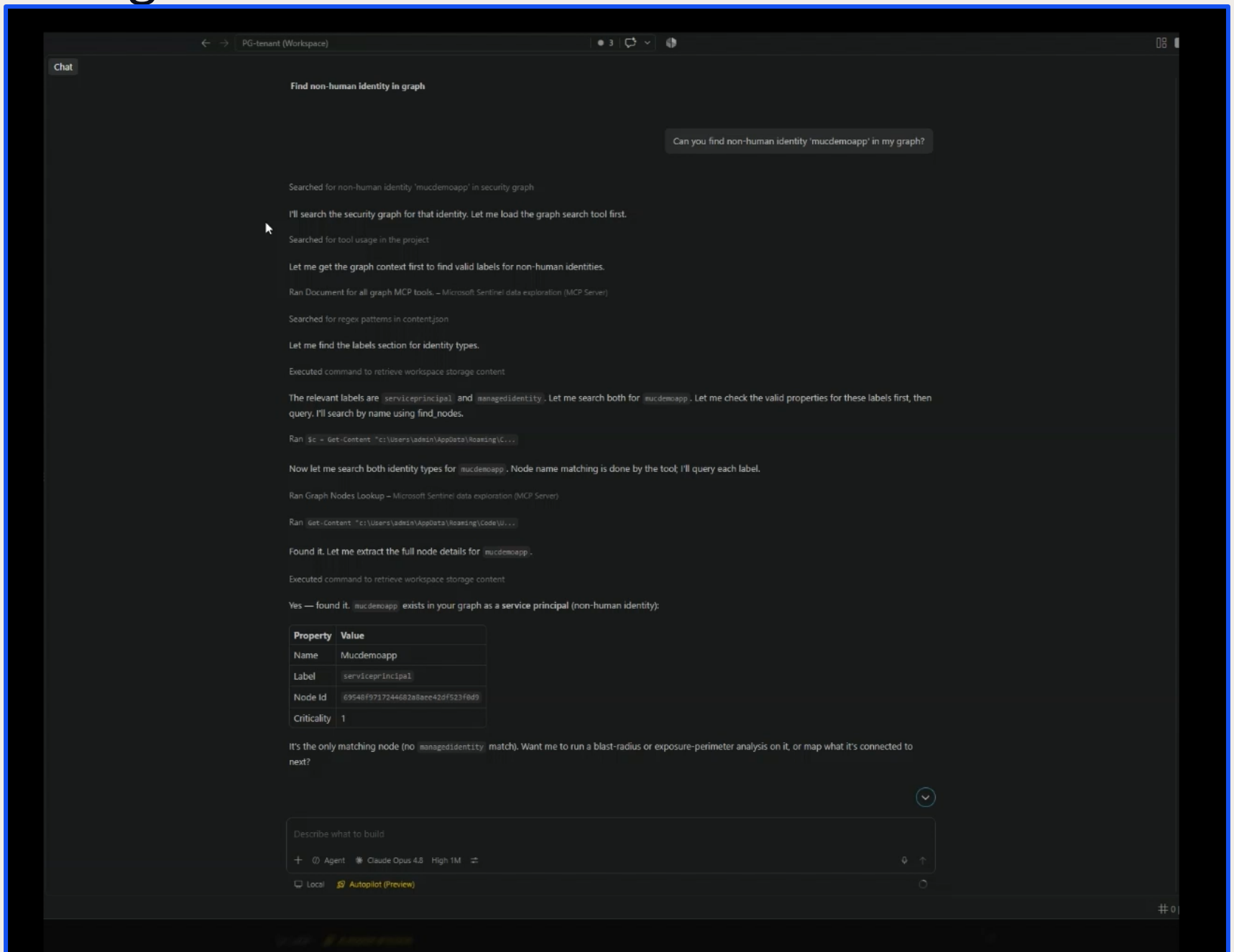
NHI Investigation



NHI Investigation



NHI through MCP



Portal vs Graph

Can you find non-human identity 'mucdemoapp' in my graph?

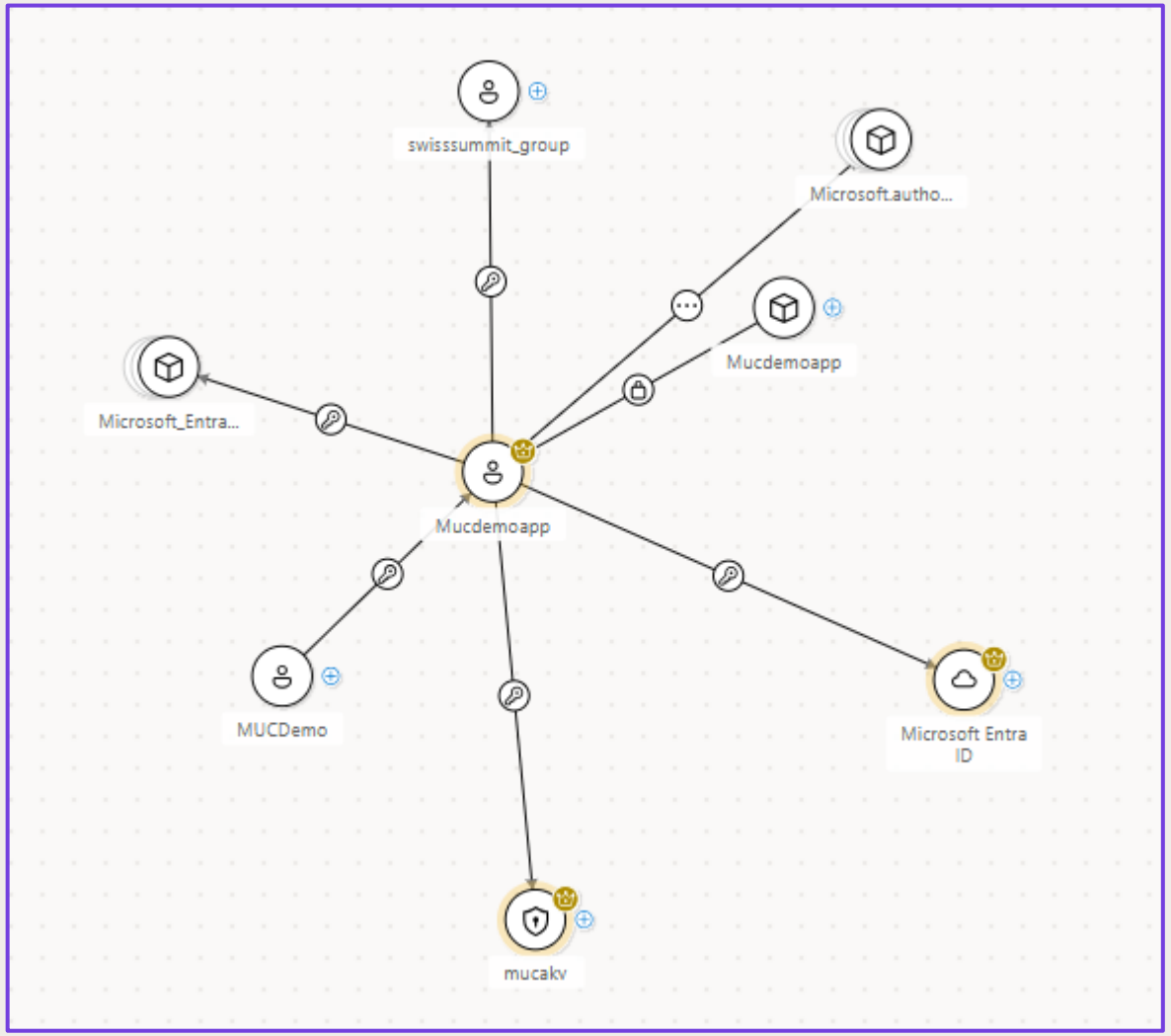
Ran `Get-Content "c:\Users\admin\AppData\Roaming\Code\U...`

Found it. Let me extract the full node details for `mucdemoapp`.

Executed command to retrieve workspace storage content

Yes — found it. `mucdemoapp` exists in your graph as a **service principal** (non-human identity):

Property	Value
Name	Mucdemoapp
Label	`serviceprincipal`
Node Id	`69548f9717244682a8aee42df523f0d9`
Criticality	1



Portal vs Graph

SECURITY NINJA GERMANY

Can you find non-human identity 'mucdemoapp' in my graph?

Ran `Get-Content "c:\Users\admin\AppData\Roaming\Code\U...`

Found it. Let me extract the full node details for `mucdemoapp`.

Executed command to retr

Yes — found it. `mucdemoa`

Property	Value
Name	Mucdemoa
Label	`servicepri`
Node Id	`69548f9717`
Criticality	1

Connected-nodes lookup complete. Note: this tool works on **actor → asset label pairs** (not a single node name), so I ran `serviceprincipal` as the source against your main asset types and filtered the results down to `mucdemoapp`.

`mucdemoapp` (serviceprincipal) — connected nodes

Edge	Target	Label	Role
has role on	swisssummit_group	resourcegroups	Virtual Machine Contributor
has assignment	(role-assignment node)	microsoft.authorization/roleassignments	—
has assignment	(role-assignment node)	microsoft.authorization/roleassignments	—

Findings:

- `mucdemoapp` holds **Virtual Machine Contributor** scoped to the `swisssummit_group` resource group. The two `has assignment` edges are the underlying Azure role-assignment plumbing for that grant.
- That VM Contributor role is why it surfaced in the VM, Cognitive Services, and Key Vault target queries — the tool returns the actor's whole neighbourhood, and VM Contributor gives it a walkable path toward those assets. It had **no match** in the storage-accounts query.
- Notably, VM Contributor includes `Microsoft.Storage/storageAccounts/listKeys/action` and `Microsoft.Compute/virtualMachines/*`, so effective reach extends beyond just VMs within that resource group.

Portal vs Graph

SECURITY NINJA GERMANY

1. The EID path exists in the graph, but `find_blastradius` didn't return it

`find_blastradius` doesn't return *every* outbound edge — it returns walkable paths that **terminate at nodes the algorithm treats as critical *targets***. In the current preview `SystemScenarioEKGGraph` projection:

- **Resource targets** (Key Vault `mucakv`, VMs, storage) are in the terminal-target set → the AKV path surfaced.
- The **Microsoft Entra ID directory node** is modeled in your screenshot as a *SaaS Application* / tenant-root — that's an **infrastructure/entrypoint-class node, not a resource "target"**. And the `has permissions to` edge into the directory is a **control-plane (Graph API) permission**, which the exposure-graph "walkable path" definition treats differently from resource RBAC used for lateral movement.

So the edge is almost certainly *present* in the graph, but it's **filtered out of the blast-radius target enumeration** — not missing data. The portal's **Attack Paths** engine models "SPN with critical directory permissions → Entra ID" as a first-class attack path; the preview MCP `find_blastradius` algorithm doesn't yet enumerate that identity-control-plane path as a terminal target.

2. The "critical asset (High)" label is from a different engine than the graph tool projects

The portal properties you circled — `criticalityLevel = High` with rule names **"SPN with Critical App Permissions to Users and Groups Management"** and **"... to Applications Management"** — are produced by the **Exposure Management critical-asset classification engine**, not stored as graph node properties the MCP `find_*` tools project.

What MCP *did* return: a **normalized** `Criticality = 1` on the node (blast-radius and find_nodes both showed it). What it did **not** return: the human-readable **High** level and the **rule names**. Per the graph skill itself (workflow step 4): *rule-based criticality and rule names require a separate data-lake query* — they live outside the graph projection. So MCP reflected *that* it's critical, just not *why* / the label.

3. The high-privilege permission detail is in `AdditionalFields`, which the tool outputs didn't project

Your second screenshot shows the edge's rich payload — `Directory.ReadWrite.All`, `Application.ReadWrite.All`, `RoleManagement.ReadWrite.Directory`, etc. Those are `AdditionalFields` / `AdditionalData` on the edge. The `find_nodes` output only projected `Id/Name/Criticality`, and `find_blastradius` only returned the single AKV path's `AdditionalData`. The permission detail exists in the graph but wasn't in the columns those specific tools returned.

Enterprise Exposure Graph vs. Graph Tools via Sentinel MCP server

What works and what does not — grounded in the 'mucdemoapp' investigation (Data Exploration graph tools, preview)

CAPABILITY	PORTAL — ENTERPRISE EXPOSURE GRAPH	SENTINEL MCP GRAPH TOOLS
Resource lateral-movement paths (Key Vault, VM, storage)	✓ Yes	✓ Yes — mucakv found
Blast radius to resource targets	✓ Yes	✓ Yes (find_blastradius)
Node/identity resolution & normalized criticality	✓ Yes	✓ Yes (Criticality = 1)
Exposure perimeter (inbound) for an actor SP	✓ Yes	● Yes, but 0 (no inbound)
Identity → Entra ID control-plane path (Directory.ReadWrite.All)	✓ Yes (Attack Paths)	✗ No — walkable_paths = 0
Critical-asset label + rule names (SPN w/ Critical App Perms)	✓ Yes (High + rules)	✗ No — numeric only
Edge permission detail (app perms in AdditionalFields)	✓ Yes	● Partial — not projected
Cost model	Free (portal graph views)	Metered per query
Agent / automation-driven (scriptable in VS Code)	✗ Manual, UI-driven	✓ Yes — agent-callable
Class-to-class relationship hunting (label → label)	● Cloud Security Explorer	✓ Yes (find_connected_nodes)

Why the gaps exist

- The preview MCP 'SystemScenarioEKGGraph' traversal models resource lateral movement; identity/directory control-plane edges are not "walkable".
- Critical-asset rule labels (High + rule names) come from the Exposure Management critical-asset engine — a separate layer; MCP returns only a normalized numeric.
- The portal's Attack Paths engine and MCP graph tools are different projections of the same underlying graph — portal is broader today for identity attack paths.

✓ works ● partial / conditional ✗ not available via MCP

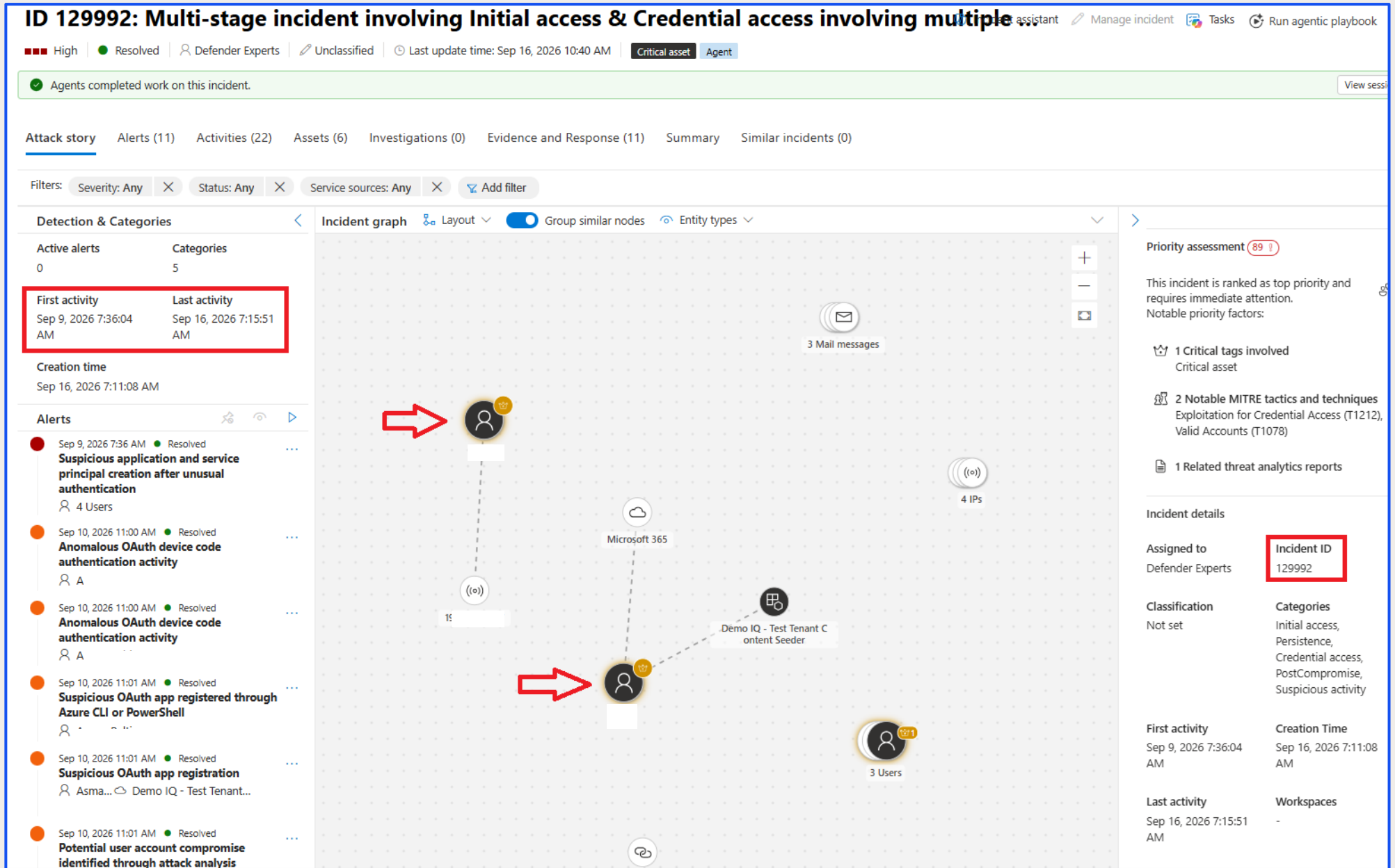
as of 2026-08-30 · graph: SystemScenarioEKGGraph · preview / metered

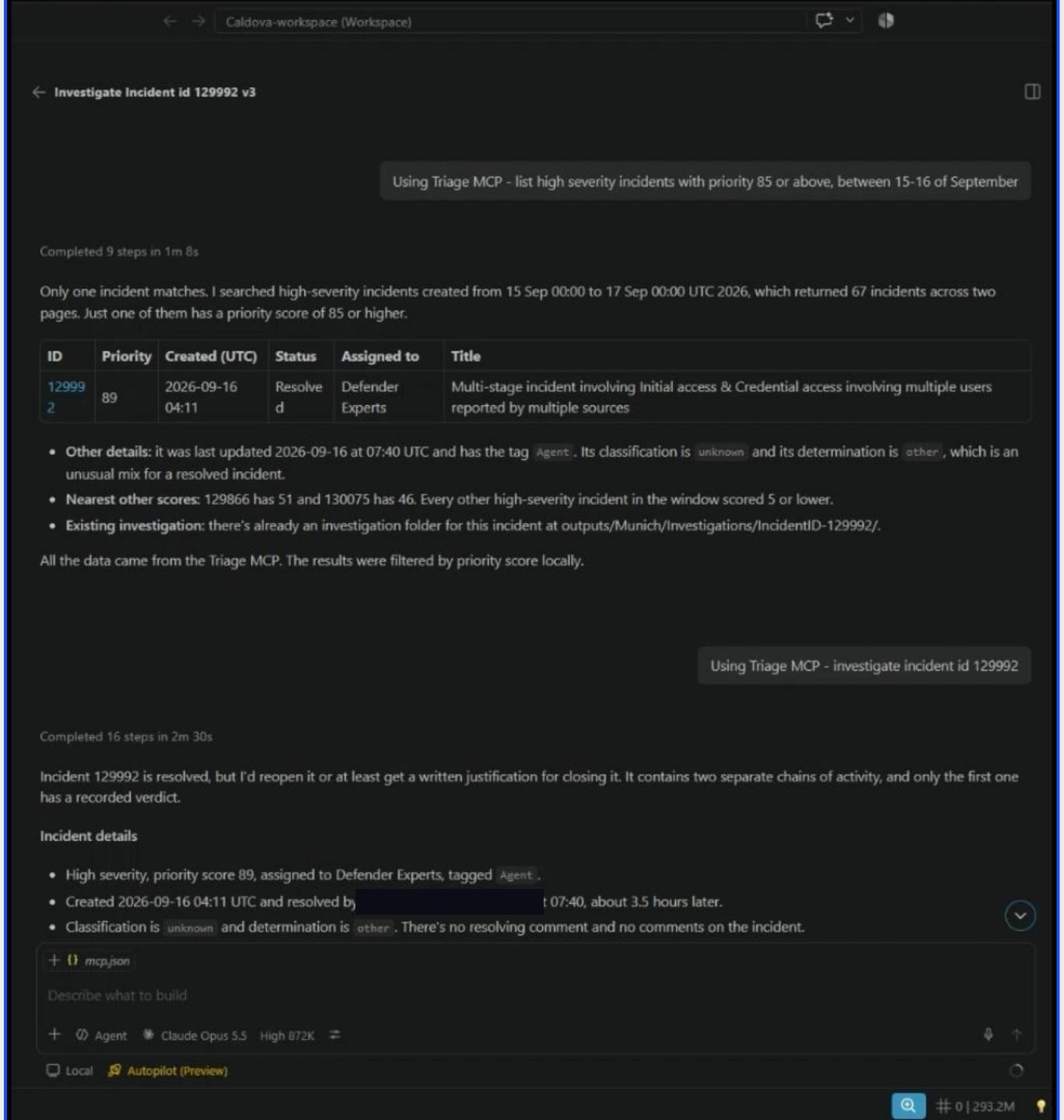
SECURITY NINJA GERMANY

Project Perception



Sentinel MCP + Perception MCP + Playbooks

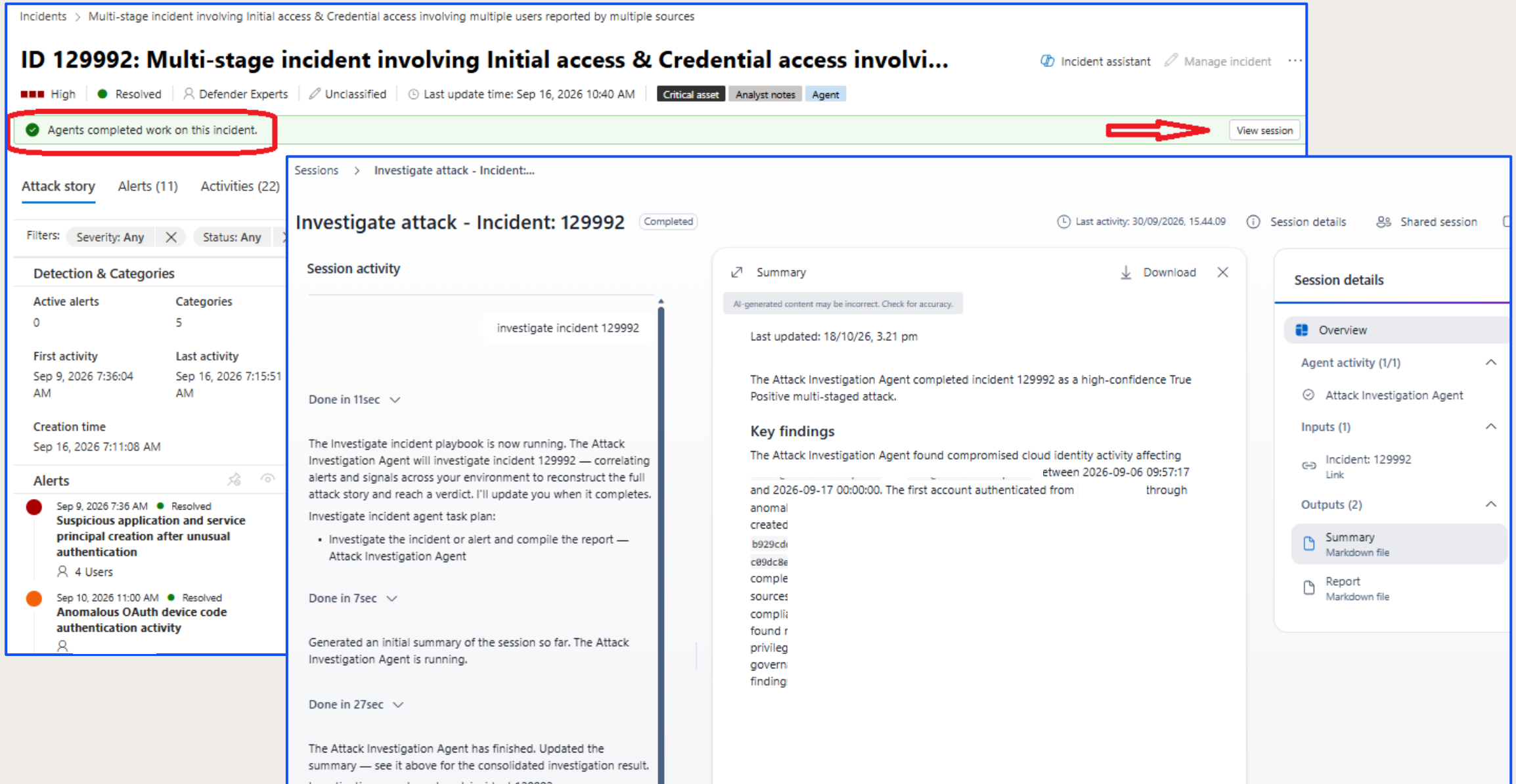



Caldova-workspace (Workspace)
Investigate Incident id 129992 v3
Using Triage MCP - list high severity incidents with priority 85 or above, between 15-16 of September
Completed 9 steps in 1m 8s
Only one incident matches. I searched high-severity incidents created from 15 Sep 00:00 to 17 Sep 00:00 UTC 2026, which returned 67 incidents across two pages. Just one of them has a priority score of 85 or higher.
ID
Priority
Created (UTC)
Status
Assigned to
Title
129992
89
2026-09-16 04:11
Resolved
Defender Experts
Multi-stage incident involving Initial access & Credential access involving multiple users reported by multiple sources
Other details: it was last updated 2026-09-16 at 07:40 UTC and has the tag Agent. Its classification is unknown and its determination is other, which is an unusual mix for a resolved incident.
Nearest other scores: 129866 has 51 and 130075 has 46. Every other high-severity incident in the window scored 5 or lower.
Existing investigation: there's already an investigation folder for this incident at outputs/Munich/Investigations/IncidentID-129992/.
All the data came from the Triage MCP. The results were filtered by priority score locally.
Using Triage MCP - investigate incident id 129992
Completed 16 steps in 2m 30s
Incident 129992 is resolved, but I'd reopen it or at least get a written justification for closing it. It contains two separate chains of activity, and only the first one has a recorded verdict.
Incident details
High severity, priority score 89, assigned to Defender Experts, tagged Agent.
Created 2026-09-16 04:11 UTC and resolved by [redacted] 07:40, about 3.5 hours later.
Classification is unknown and determination is other. There's no resolving comment and no comments on the incident.
mcp.json
Describe what to build
Agent
Claude Opus 5.5
High 872K
Local
Autopilot (Preview)
0 | 293.2M

Investigation Summary - SVGs



Triage & Perception Combined



SECURITY NINJA GERMANY

Auditing



Who did what with Sentinel data? Auditing at a glance

People, AI agents and services across Sentinel and Microsoft Fabric | as of 2026-10-01

WHO ACTS

People
SOC analysts and admins
Defender portal · VS Code

AI agents
Security Copilot · Copilot Studio · Foundry · VS Code · other MCP clients

Services
Lake jobs · Fabric connections
Write-back to Sentinel

IDENTITY GATE

Microsoft Entra ID
People and agents sign in
Conditional Access for people and agents
→ **Entra sign-in logs**
Tells you who and which app or agent

WHERE DATA IS USED

Sentinel SIEM
Configuration · analytics queries

Sentinel data lake & graph
KQL · notebooks · jobs · graph
MCP tools used by agents

Microsoft Fabric
Mirrored Sentinel data · notebooks · KQL · graph
Workspace permissions don't apply

API / PLATFORM LAYER

Microsoft Graph activity logs
Graph API calls · token ID links to sign-ins
Doesn't see Sentinel MCP calls

WHERE IT'S RECORDED

Azure Activity & query logs
Configuration changes · queries

Microsoft Purview Audit
Lake, graph and AI tool actions

Microsoft Defender XDR
via Defender for Cloud Apps*

Fabric audit + OneLake diagnostics
Fabric actions · data reads

Log Analytics workspace
Entra logs via diagnostic settings
Optional Purview feed (API + DCR)

KEY GAPS

1 Fabric reads bypass workspace permissions and the Sentinel audit trail

2 Purview shows the tool interface, not the agent platform: use the sign-in app ID

3 Prompts to non-Microsoft AI models aren't audited by default

LINK THE TRAIL

Who and which agent
Entra sign-in logs: user and app ID

What was done
Purview, Defender XDR or Log Analytics: join on user + time

What happened in Fabric
Separate trail: Fabric audit + OneLake diagnostics

TOP ACTIONS

1 Govern Fabric mirroring

2 Bring Purview records into Sentinel

3 Extend audit retention

4 Conditional Access on Sentinel for people and agents

5 Detect new agents and unusual data use

Sentinel Data Lake & Agentic Tools — Auditing

Agents · SIEM · data lake & graph · Fabric | Microsoft Learn + PG-Tenant evidence · as of 2026-10-01

▲ Fabric mirrored item = new attack surface: own access review)
▲ Prompt text isn't a documented Copilot audit attribute (Messages = IDs + flags)

AGENT PLATFORM ZONE

Model runs in the client's platform · Sentinel MCP server is model-agnostic

Microsoft Security Copilot
ID Custom agent + MCP plugin · TokenScope 4500ebfb.../.default
Prompt CopilotInteraction · Copilot.Security.SecurityCopilot · Audit Standard
Tools SentinelAIToolRun*

Microsoft Copilot Studio
ID Built-in: Entra ID Integrated · Custom: app reg + secret (SentinelPlatform.DelegatedAccess)
Prompt CopilotInteraction · Copilot.Studio.<AppId> · Audit Standard
Tools SentinelAIToolRun*

Microsoft Foundry
ID Custom: OAuth Identity Passthrough + app reg + secret
Prompt Audit Standard · record type **[U]**
Tools SentinelAIToolRun*

Visual Studio Code (any model)
ID Entra user · AppId Visual Studio Code
Prompt **Not in Purview** (none observed)
Tools SentinelAIToolRun* · notebooks Interface = VSCE

Other MCP clients
ChatGPT · Claude · Azure Logic Apps · Sentinel CLI
ID Entra user
Prompt AIAppInteraction only with pay-as-you-go · desktop **[U]**
Tools SentinelAIToolRun*

IDENTITY & ACCESS

Entra OAuth 2.0 · MCP Streamable HTTP

Microsoft Entra ID
Access token claims uti · sid · oid · deviceid
deviceid only for registered / joined devices

Sentinel Platform Services
Resource 4500ebfb-89b6-4b14-a480-7f749797bfcd
Sign-in AppId identifies the calling host

Allowed callers
Users · managed identities · service principals
Security Reader / Operator / Administrator
Entity analyzer: + Security Copilot Contributor (SCU)

Conditional Access (target)
Users MFA + compliant device
Agents Block except approved blueprints + Agent risk
Agent CA = Block only; needs E7 or Agent 365

Microsoft Entra Agent ID
agentSignIn in any of the four sign-in tables
Audit under base identity type (agentType)

SENTINEL SIEM · analytics tier

Config · rules · interactive queries
Portal config → AzureActivity (MICROSOFT.SECURITYINSIGHTS/*)
Analytics rules → SentinelAudit (analytics rules only)
Interactive queries → LAQueryLogs (not on by default)
Learn conflict on Advanced hunting coverage; M365D_AdvancedHunting observed

SENTINEL DATA LAKE & GRAPH

Lake KQL · notebooks · jobs · graph · MCP tools
→ **Purview Audit categories:** onboarding · notebook · job · KQL · AI tool · graph · CMK
Interface values: IMcpToolExecutorComponent · HttpMcpToolExecutorComponent · VSCE (don't name the platform)
Advanced hunting over lake tier → **[U] no audit record proven**
Scoping: new data only · no XDR tables · notebooks blocked for scoped users

MICROSOFT FABRIC LANE

Mirrored Azure Monitor item
Read-only · no copy · new data only
Connection: workspace identity | OAuth | SP + SAS

OneLake shortcuts → analytics
Eventhouse KQL · Lakehouse / Spark notebooks
Pipelines · Fabric Graph (GQL)

NOT enforced: Azure RBAC · LA RLS/CLS · table protection · reuse = Fabric workspace access only

Federation
Metadata mirroring · external shortcuts · Sentinel data federation

DCR write-back → SIEM
App reg + secret · client credentials → Logs Ingestion API → custom table

Fabric activities

AUDIT SINKS · unified audit + API/platform layers

Microsoft Entra
SigninLogs · AADNonInteractiveUserSignInLogs
AADServicePrincipalSignInLogs · AADManagedIdentitySignInLogs
All carry UniqueTokenIdentifier
MicrosoftGraphActivityLogs · Entra audit (agentType)
Retention: workspace

Azure Activity / Log Analytics
AzureActivity · SentinelAudit · LAQueryLogs
Optional SentinelPlatformAuditLogs_CL (blog pattern: Management API + DCR)
Retention: workspace

Microsoft Purview Audit
Sentinel: KQLQueryCompleted · SessionStarted/Stopped · TableRead · CustomTableWrite/Delete · Job* · SentinelAIToolRunStarted/Completed/Created · GraphQueryRun · GraphScenarioCreated/Deleted · SentinelLake* · CMK*
AI: CopilotInteraction · ConnectedAIAppInteraction · AIAppInteraction
Fabric: Fabric activities
Retention: Standard 180 d · Premium policy ≤ 1 yr (10 yr add-on) · SP records fixed 1 yr · pay-as-you-go AI apps 180 d

Defender XDR · CloudAppEvents
From Purview via Defender for Cloud Apps
Sentinel ops (Application = Microsoft 365)
Fabric ops (Application = Microsoft Power BI)
Sentinel ops: Sentinel blog + tenant, not on Learn
Needs Microsoft 365 activities app connector
Retention: 30 d in Advanced hunting unless streamed

Fabric / OneLake
Fabric activities (item level, in Purview)
OneLake diagnostics (data plane, immutable lakehouse)
ModifyOneLakeDiagnosticSettings
Retention: Purview · own diagnostics cleanup

CORRELATION LAYER · join keys

Analyst-side KQL across independent tables · no log feeds another, except Purview → CloudAppEvents (observed)

Sign-in logs ↔ Graph activity logs
UTI = SignInActivityId · SessionId

SP sign-in logs ↔ Graph activity logs
UTI works for app-only and agent flows

Sentinel Purview records ↔ sign-ins
AppAccessContext absent on 1,606/1,606

Sentinel Purview records ↔ sign-ins
UserId + time · fails on UserIdNotProvided

Agent platform ↔ host
Sign-in AppId on resource 4500ebfb...

Agent platform ↔ host
Purview Interface doesn't name the platform

Agent identity type
Agent column · agentType · AppId join

Fabric read ↔ Sentinel lake audit
No join · separate trails

Fabric item ops ↔ user
Fabric activity UserId

Fabric data-plane read ↔ user
OneLake diagnostics · shortcut coverage **[U]**

DCR write ↔ writer
SP sign-in to monitor.azure.com only

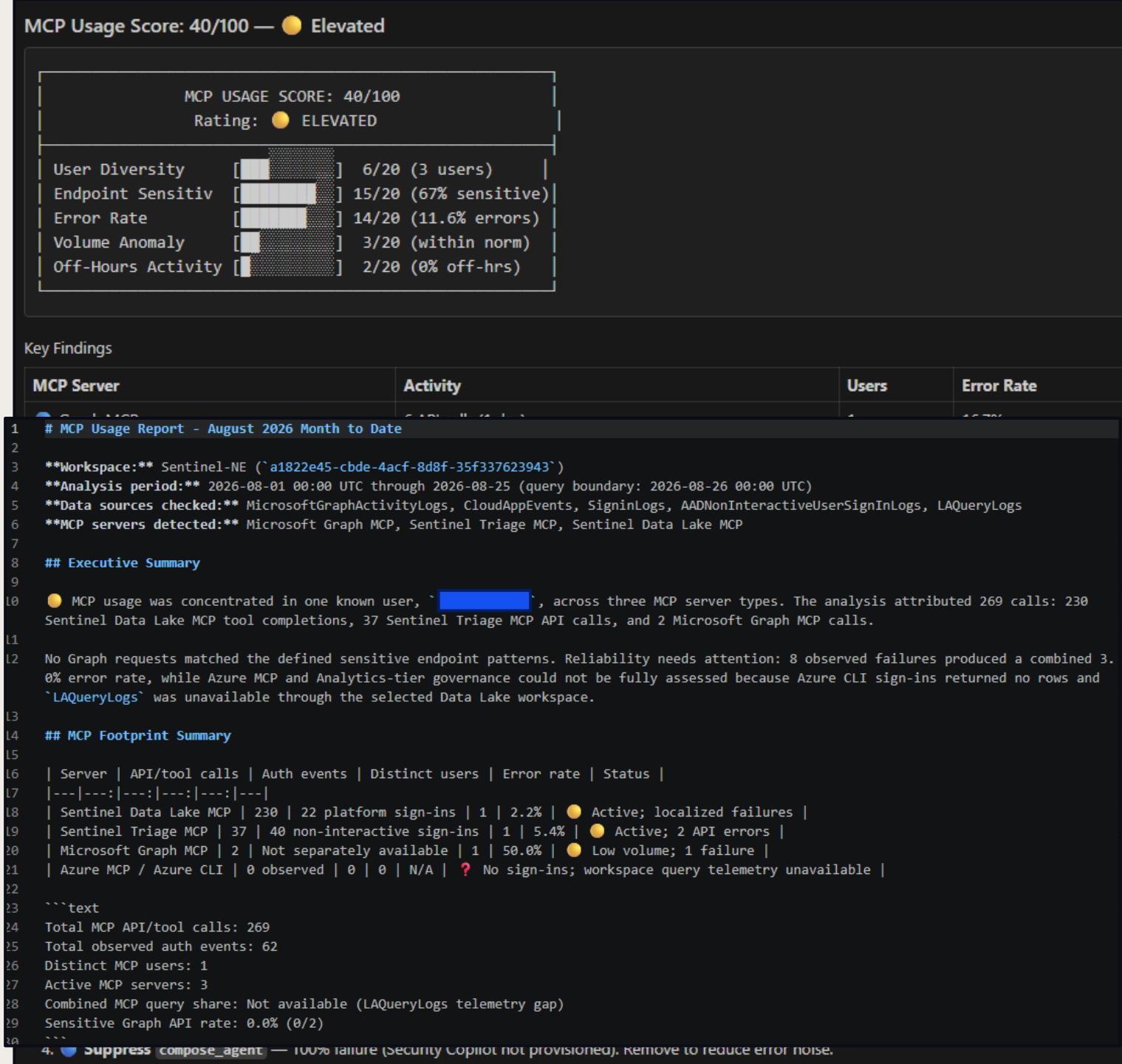
Advanced hunting lake query ↔ user
No record proven **[U]**

■ works ■ weak ■ doesn't work

Auditing MCP Usage – How?

- With MCP servers and custom skills☺
- Chris Stelzer @Microsoft – Security Investigator

https://github.com/SCStelz/security-investigator



MCP Usage Monitoring Dashboard

Sentinel-NE | Jul 30 - Aug 28, 2026 | Generated Aug 28, 2026

MCP Usage Score

39/100

ELEVATED

3

Tota

Score Dimensions

User diversity	3/20
Sensitive endpoints	0/20
Error rate	13/20
Volume anomaly	3/20
Off-hours activity	20/20

Top Endpoints and Tools

Data Lake - find_nodes	
Data Lake - get_graph_context	
Data Lake - query_lake	
Triage - runHuntingQuery	36
Data Lake - search_tables	21

Red overlay shows failed calls. Data Lake MCP produced 17 total failures.

Weekly MCP Activity Trend

Data Lake series uses the Query 1 probable-MCP proxy; definitive tool total is 292.



MCP Usage Investigation Map

Sentinel-NE | Aug 1-25, 2026 UTC | Evidence-based attribution across five telemetry surfaces

TELEMETRY SOURCES

MicrosoftGraphActivityLogs
Graph MCP and dedicated Triage AppIds
39 definitive API records

CloudAppEvents
RecordType 403 tools and 379 KQL audit
230 definitive MCP tool completions

Sign-in Logs
Interactive and non-interactive authentication
User, resource, country, and client attribution

LAQueryLogs
Analytics-tier query governance
Empty in AH; unresolved in Data Lake

AzureActivity
ARM write-operation evidence
Not verified after required query stop

ATTRIBUTION AND ANALYSIS

Dedicated AppId correlation
Graph: e8c77dc2 | Triage: 7b7b3966
Definitive server and user attribution

Audit-record classification
RecordType 403 = MCP tool; 379 = direct/proxy KQL
Prevents portal and MCP activity conflation

Cross-server user resolution
Object ID joined to recent sign-in UPN evidence
One known user across three MCP servers

Error and sensitivity analysis
HTTP errors, tool failures, endpoint patterns, off-hours
8 failures; no sensitive Graph endpoint matches

Governance boundary
No retry after LAQueryLogs workspace failure

INVESTIGATION OUTCOMES

269 attributable calls
230 Data Lake + 37 Triage + 2 Graph
Three active MCP server types

One known operator
sipa@feta.fi spans Graph, Triage, and Data Lake
No app-only agent/SPN caller observed

Reliability issue localized
3 schema failures + 2 entity-window failures
Combined attributable error rate: 3.0%

No sensitive Graph access
0 of 2 calls matched sensitive endpoint patterns
Delegated certificate authentication only

Visibility remains incomplete
Query share, Azure MCP queries, and ARM writes
Not verified; no absence claim made

ELEVATED | MCP Usage Score 28/100

Primary interpretation: concentrated but attributable usage, no sensitive Graph access, and correctable reliability failures.

Next: correct schema assumptions, enforce the seven-day entity-analysis window, and restore LAQueryLogs visibility.

VERIFIED FAILURES
8 / 269

SECURITY NINJA GERMANY

Key Takeaways

- **Data lake eliminates blind spots:** 12 years of retention; a breach that began two years ago is still investigable
- **Graph turns entities into attack paths:** Blast radius, lateral paths, and exposure perimeters, not just a list of logs
- **Portal graphs are free; agentic graph is metered (Fabric):** MCP, API, and notebook queries bill per vCore-hour - needs budget estimations before scaling it up
- **Sentinel MCP & multi-tenant:** delegated access needs a signed-in user in every tenant - Foundry + REST APIs is the supported path
- **Secure and audit the agentic path together:** Entra auth makes MCP traceable (SessionId + UTI in Purview UAL); gate it with AI Gateway and Global Secure Access. Personal GitHub OAuth leaves no Entra trail

Thank you to our Sponsors!

Host Partner

Microsoft

Gold

glueck kanja

water IT Security & Defense

robopack

PROACT

Silver

WORKSIMPLE EINFACH ARBEITEN

semperis

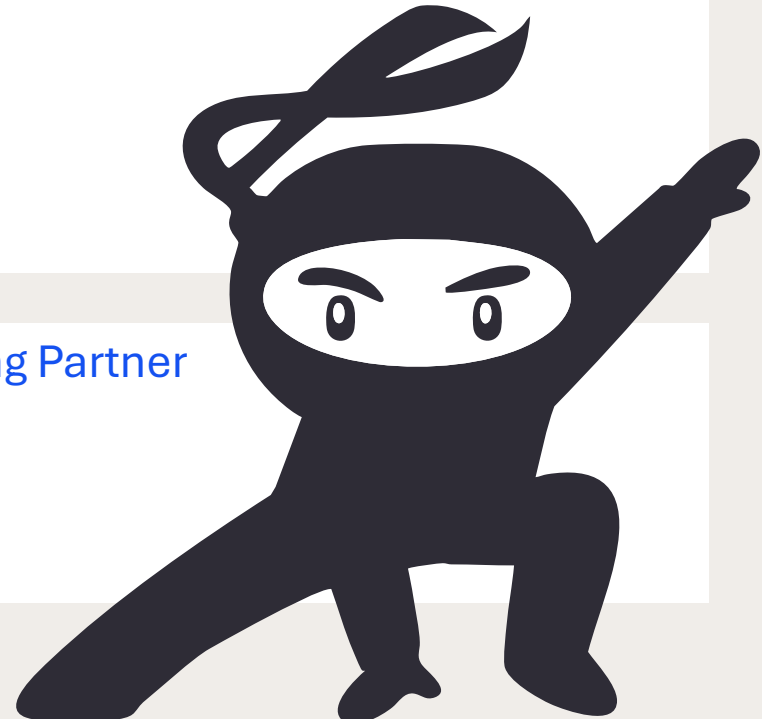
Bronze

ugurlabs

IC CONSULT

Snacks & Networking Partner

SCE



Thank You, Ninjas!

